CÔNG TY CỔ PHẦN XOR CLOUD

BỘ HỒ SƠ MẪU
ĐỀ XUẤT CẤP ĐỘ 4
HỆ THỐNG X-OR SECURE CLOUD

Thuyết minh tổng quan, căn cứ đề xuất cấp độ, đánh giá rủi ro, thiết kế và phương án bảo đảm an ninh mạng

Phiên bản 0.9.4 - Mẫu hoàn thiện hồ sơ
Hà Nội, tháng 10 năm 2026

THÔNG TIN KIỂM SOÁT TÀI LIỆU

Thuộc tính	Giá trị
Tên tài liệu	Bộ hồ sơ mẫu đề xuất Cấp độ 4 - Hệ thống X-OR SECURE CLOUD
Mã tài liệu	XOR-XSC-ANM-L4-DOSSIER
Phiên bản	0.9.4
Ngày lập	06/10/2026
Mức độ lưu hành	Nội bộ - phục vụ xây dựng, xin ý kiến, thẩm định và phê duyệt
Chủ trì soạn thảo	Khối Hạ tầng
Chủ quản HTTT	Công ty Cổ phần XOR CLOUD
Đơn vị vận hành	Khối Hạ tầng
Đơn vị chuyên trách ANM	Trung tâm Vận hành
Tình trạng	Mẫu hồ sơ - chưa phải hồ sơ đã phê duyệt; phải cập nhật as-built và bằng chứng nghiệm thu trước khi trình chính thức.

LỊCH SỬ PHIÊN BẢN

Phiên bản	Ngày	Nội dung	Người lập/phê duyệt
0.9	15/09/2026	Lập mẫu hồ sơ Cấp độ 4 trên cơ sở thiết kế mục tiêu X-OR SECURE CLOUD và checklist 129 kiểm soát.	[CẦN BỔ SUNG]
0.9.1	16/09/2026	Đồng bộ tên hệ thống thành Hệ thống X-OR SECURE CLOUD và Chủ quản HTTT là Công ty Cổ phần XOR CLOUD.	[CẦN BỔ SUNG]
0.9.2	05/10/2026	Vẽ lại kiến trúc phân vùng bảo mật X-OR SECURE CLOUD cho hồ sơ Cấp độ 4; bổ sung ranh giới vùng biên, DMZ, tenant, quản trị/control, dữ liệu/lưu trữ, SOC/ANM và Backup/DR.	[CẦN BỔ SUNG]
0.9.3	06/10/2026	Cập nhật chức danh Trần Văn Dũng; thiết kế lại hệ đường kết nối của sơ đồ kiến trúc phân vùng bảo mật theo luồng dịch vụ, quản trị, dữ liệu và DR.	[CẦN BỔ SUNG]

Phiên bản	Ngày	Nội dung	Người lập/phê duyệt
0.9.4	06/10/2026	Cập nhật BOM V4: 09 server + 01 SAN; FortiGate 500E. Vẽ lại zone và hạ tầng A/B trên trang ngang; đối chiếu VLAN, network đồng vị trí và điểm lỗi đơn.	[CẦN BỔ SUNG]
1.0	[dd/mm/yyyy]	Hoàn thiện sau khi có as-built, hồ sơ DC, pentest, DR và ý kiến chuyên môn.	[CẦN BỔ SUNG]

PHÊ DUYỆT NỘI BỘ

Vai trò	Họ tên/chức vụ	Ý kiến	Ký, ngày
Đơn vị lập	Chử Quang Thắng – Giám đốc Vận hành		
Đơn vị vận hành	Trần Văn Dũng – Giám đốc Khối Hạ tầng & Vận hành		
Đơn vị chuyên trách ANM	Trần Văn Dũng – Giám đốc Khối Hạ tầng & Vận hành		
Chủ quản HTTT	Lê Anh Vũ - Tổng Giám đốc		

MỤC LỤC

THÔNG TIN KIỂM SOÁT TÀI LIỆU....2
LỊCH SỬ PHIÊN BẢN....2
PHÊ DUYỆT NỘI BỘ....3
MỤC LỤC....4
DANH MỤC THÀNH PHẦN BỘ HỒ SƠ....6
1. Thông tin chủ quản, vận hành và các bên liên quan....8
2. Mục tiêu và phạm vi dịch vụ....8
3. Quy mô và kiến trúc mục tiêu....9
4. Danh mục thiết bị giai đoạn 1....12
5. Phân vùng mạng và luồng dữ liệu....13
6. Phụ thuộc và hệ thống liên quan....15
1. Nguyên tắc thiết kế Cấp độ 4....16
2. Thiết kế HA và khả năng chịu lỗi....17
3. Yêu cầu cấu hình an toàn nền tảng....17
4. Tiêu chí nghiệm thu thiết kế....18
1. Nguyên tắc xác định cấp độ....19
2. Ma trận lập luận đề xuất....19
3. Đề xuất câu chữ sau khi đủ bằng chứng....20
4. Ranh giới giữa Cấp độ HTTT và Tier/Rating DC....20
1. Phương pháp đánh giá....21
2. Kế hoạch xử lý rủi ro ưu tiên....24
1. Quản trị, pháp lý và hồ sơ cấp độ....25
2. Quản lý tài sản, cấu hình và thay đổi....25
3. IAM, PAM và kiểm soát đặc quyền....25
4. An ninh mạng và phòng thủ biên....25
5. An toàn máy chủ, ảo hóa và nền tảng OpenStack....26
6. An toàn container, chuỗi cung ứng và DevSecOps....26
7. An toàn dữ liệu, mã hóa và quản lý khóa....26
8. Nhật ký, giám sát và SOC 24/7....26
9. Quản lý lỗ hổng, bản vá và kiểm thử....27
10. Sao lưu, liên tục kinh doanh và DR....27
11. Ứng cứu sự cố và điều tra số....27
12. Trung tâm dữ liệu và an ninh vật lý....27

13. Nhân sự, nhà cung cấp và kiểm toán.....28
14. Mô hình trách nhiệm chia sẻ.....28
1. Lộ trình đóng khoảng trống.....30
2. Bộ tiêu chí nghiệm thu tối thiểu.....30
PHỤ LỤC D. MA TRẬN 129 KIỂM SOÁT CẤP ĐỘ 4.....35
PHỤ LỤC F. DANH MỤC CĂN CỨ VÀ TÀI LIỆU THAM CHIẾU.....94
PHỤ LỤC G. CHECKLIST TRƯỚC KHI KÝ/TRÌNH.....95

Ghi chú: Mục lục là trường tự động của Word; cập nhật toàn bộ trường trước khi ký số hoặc phát hành.

DANH MỤC THÀNH PHẦN BỘ HỒ SƠ

STT	Thành phần theo Nghị định 331/2026/NĐ-CP	Vị trí trong tài liệu	Trạng thái mẫu
1	Văn bản đề nghị thẩm định, phê duyệt hồ sơ đề xuất cấp độ	Phần I	Có mẫu; cần điền chủ thể và cơ quan nhận
2	Tài liệu mô tả, thuyết minh tổng quan về HTTT	Phần II	Đã mô tả theo thiết kế mục tiêu; cần cập nhật as-built
3	Tài liệu thiết kế sơ bộ hoặc tài liệu có giá trị tương đương	Phần III	Có thuyết minh; cần bổ sung bản vẽ phê duyệt, IP plan, rack/port map
4	Tài liệu thuyết minh đề xuất cấp độ	Phần IV	Có mẫu lập luận; tiêu chí Cấp độ 4 phải được chủ quản chứng minh
5	Báo cáo đánh giá rủi ro chi tiết đối với Cấp độ 4	Phần V	Có phương pháp và risk register mẫu; cần workshop xác nhận
6	Thuyết minh phương án bảo đảm ANM tương ứng	Phần VI	Có thiết kế đầy đủ theo 21 nhóm/129 kiểm soát
7	Ý kiến chuyên môn của đơn vị chuyên trách ANM	Phụ lục A	Có mẫu văn bản
8	Ý kiến thẩm định và quyết định phê duyệt	Phụ lục B-C	Có mẫu văn bản
9	Ma trận kiểm soát, bằng chứng và kế hoạch hoàn thiện	Phụ lục D-E	Có 129 dòng, giữ nguyên trạng thái hiện tại

PHẦN I

Văn bản đề nghị thẩm định, phê duyệt hồ sơ đề xuất cấp độ

CÔNG TY CỔ PHẦN XOR CLOUD

Số: .../CV-...

CỘNG HÒA XÃ HỘI CHỦ NGHĨA VIỆT NAM

Độc lập - Tự do - Hạnh phúc

Hà Nội, ngày ... tháng ... năm 2026

V/v đề nghị thẩm định, phê duyệt hồ sơ đề xuất Cấp độ 4

Kính gửi: [CƠ QUAN/ĐƠN VỊ CÓ THẨM QUYỀN THẨM ĐỊNH]

Căn cứ Luật An ninh mạng số 116/2025/QH15; Nghị định số 331/2026/NĐ-CP ngày 19/08/2026 của Chính phủ về bảo vệ an ninh mạng đối với hệ thống thông tin; Nghị định số 333/2026/NĐ-CP ngày 19/08/2026 và các văn bản có liên quan;

CÔNG TY CỔ PHẦN XOR CLOUD đề nghị thẩm định, phê duyệt hồ sơ đề xuất cấp độ đối với Hệ thống X-OR SECURE CLOUD, với các thông tin sau:

Nội dung	Thông tin
Tên hệ thống thông tin	Hệ thống X-OR SECURE CLOUD
Chủ quản hệ thống thông tin	Công ty Cổ phần XOR CLOUD
Đơn vị vận hành	Khối Vận hành
Địa chỉ	Tầng 7, Tòa nhà Việt Á, Số 09 phố Duy Tân, Phường Cầu Giấy, TP Hà Nộ
Cấp độ đề xuất	Cấp độ 4
Căn cứ đề xuất	Phạm vi toàn quốc và vận hành 24/7

Hồ sơ kèm theo gồm: (1) thuyết minh tổng quan; (2) tài liệu thiết kế; (3) thuyết minh đề xuất cấp độ; (4) báo cáo đánh giá rủi ro chi tiết; (5) thuyết minh phương án bảo đảm an ninh mạng; (6) ý kiến chuyên môn của đơn vị chuyên trách an ninh mạng; và các phụ lục bằng chứng liên quan.

Kính đề nghị Quý Cơ quan xem xét, tổ chức thẩm định và có ý kiến để Công ty Cổ phần XOR CLOUD hoàn thiện, phê duyệt hồ sơ theo thẩm quyền.

Nơi nhận	ĐẠI DIỆN CƠ QUAN, TỔ CHỨC
- Như trên; - Lưu: VT, ...	(Ký, ghi rõ họ tên, chức danh và đóng dấu)

PHẦN II

Thuyết minh tổng quan về hệ thống thông tin

1. Thông tin chủ quản, vận hành và các bên liên quan

Chủ thể	Vai trò tối thiểu	Thông tin cần hoàn thiện
Chủ quản HTTT	Quyết định phạm vi, mục tiêu, cấp độ; phê duyệt hồ sơ, rủi ro chấp nhận, nguồn lực và phương án bảo vệ.	Tên pháp nhân; chức năng; người đại diện; địa chỉ; điện thoại; email; quyết định giao chủ quản.
Đơn vị vận hành	Vận hành 24/7; quản trị cấu hình, sự cố, thay đổi, sao lưu; duy trì bằng chứng.	Quyết định giao vận hành; sơ đồ tổ chức; đầu mối NOC/SOC; RACI.
Đơn vị chuyên trách ANM	Cho ý kiến chuyên môn; giám sát tuân thủ; không đồng thời tự thẩm định nếu thiếu cơ chế độc lập.	Quyết định thành lập/giao nhiệm vụ; năng lực; đầu mối.
Nhà cung cấp DC/colo	Cung cấp điện, lạnh, PCCC, an ninh vật lý, kết nối và bằng chứng DC theo hợp đồng.	Hợp đồng/SLA; công bố phù hợp TT42; TCCF; MEP; MOP/SOP/EOP.
Khách hàng/tenant	Quản trị workload, tài khoản, dữ liệu, cấu hình guest và ứng dụng theo mô hình trách nhiệm chia sẻ.	DPA/SLA; phân loại dữ liệu; RPO/RTO; owner hệ thống thuê.

2. Mục tiêu và phạm vi dịch vụ

Hệ thống X-OR SECURE CLOUD cung cấp tài nguyên điện toán, mạng, lưu trữ và dịch vụ quản trị cho nhiều tenant trên kiến trúc OpenStack/Kolla, hypervisor KVM và Ceph SSD. Giai đoạn 1 theo quy hoạch V4 gồm 09 máy chủ và 01 SAN. Các thành phần portal, broker/API gateway, bảo vệ an ninh mạng và sao lưu là dịch vụ phần mềm hoặc máy ảo trên nền tảng, không được tính thêm thành máy chủ vật lý trong BOM.

- IaaS: máy chủ ảo, image, flavor, volume, snapshot, mạng riêng ảo, router ảo, security group, floating IP và cân bằng tải khi được triển khai.
- Dịch vụ quản trị: portal/API, identity, quota, billing/usage, inventory/CMDB, giám sát, log, cảnh báo, hỗ trợ và quản lý thay đổi.
- Dịch vụ dữ liệu: block storage trên cụm 03 Ceph SSD; 01 SAN với 24 ổ 600 GB SAS có vai trò/backend riêng theo thiết kế được phê duyệt; sao lưu và phục hồi theo chính sách. BOM V4 chưa có cụm Ceph HDD hoặc hệ S3 độc lập, nên không mặc định các dịch vụ này đã được triển khai.
- Phạm vi bảo vệ được chia thành các vùng logic: vùng ngoài/không tin cậy; vùng biên an ninh; DMZ và dịch vụ công khai; vùng dịch vụ cloud/tenant data plane; vùng quản trị và control plane; vùng dữ liệu/lưu trữ; vùng SOC, an ninh mạng và sao lưu. Mọi luồng liên vùng phải đi qua điểm kiểm soát được phê duyệt, áp dụng deny-by-default, xác thực mạnh, ghi log và giám sát tập trung.

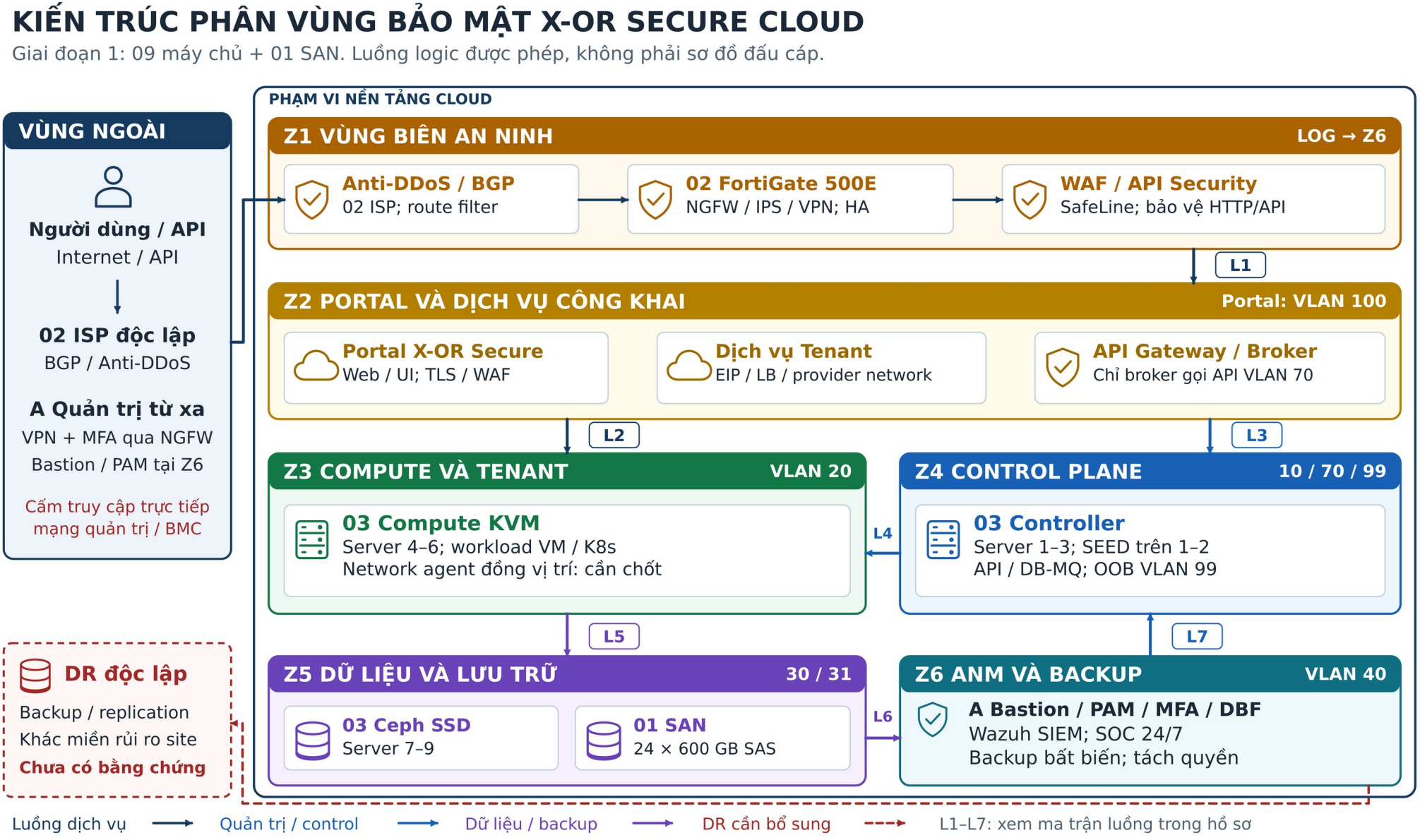
- Ngoài phạm vi nền tảng nhưng có giao diện trách nhiệm: hệ điều hành khách, ứng dụng, tài khoản ứng dụng, dữ liệu tenant và kiểm soát nghiệp vụ do khách hàng quản trị, trừ khi hợp đồng quy định khác.

3. Quy mô và kiến trúc mục tiêu

Quy mô giai đoạn 1 gồm 09 máy chủ Dell R630: 03 Controller (Server 1–3, Server 1–2 kiêm SEED), 03 Compute KVM (Server 4–6) và 03 Ceph SSD (Server 7–9). Thiết bị bổ trợ gồm 01 SAN, 02 Cisco Nexus N9K-C93180YC-EX, 02 FortiGate 500E, 01 switch SAN và 01 switch Access. Không bố trí 02 Network node vật lý riêng hoặc 03 Ceph HDD như phương án trước. Chức năng Neutron/OVN, gateway và HA network phải được lựa chọn mô hình đồng vị trí, phân bổ dịch vụ và kiểm thử trước triển khai chính thức.

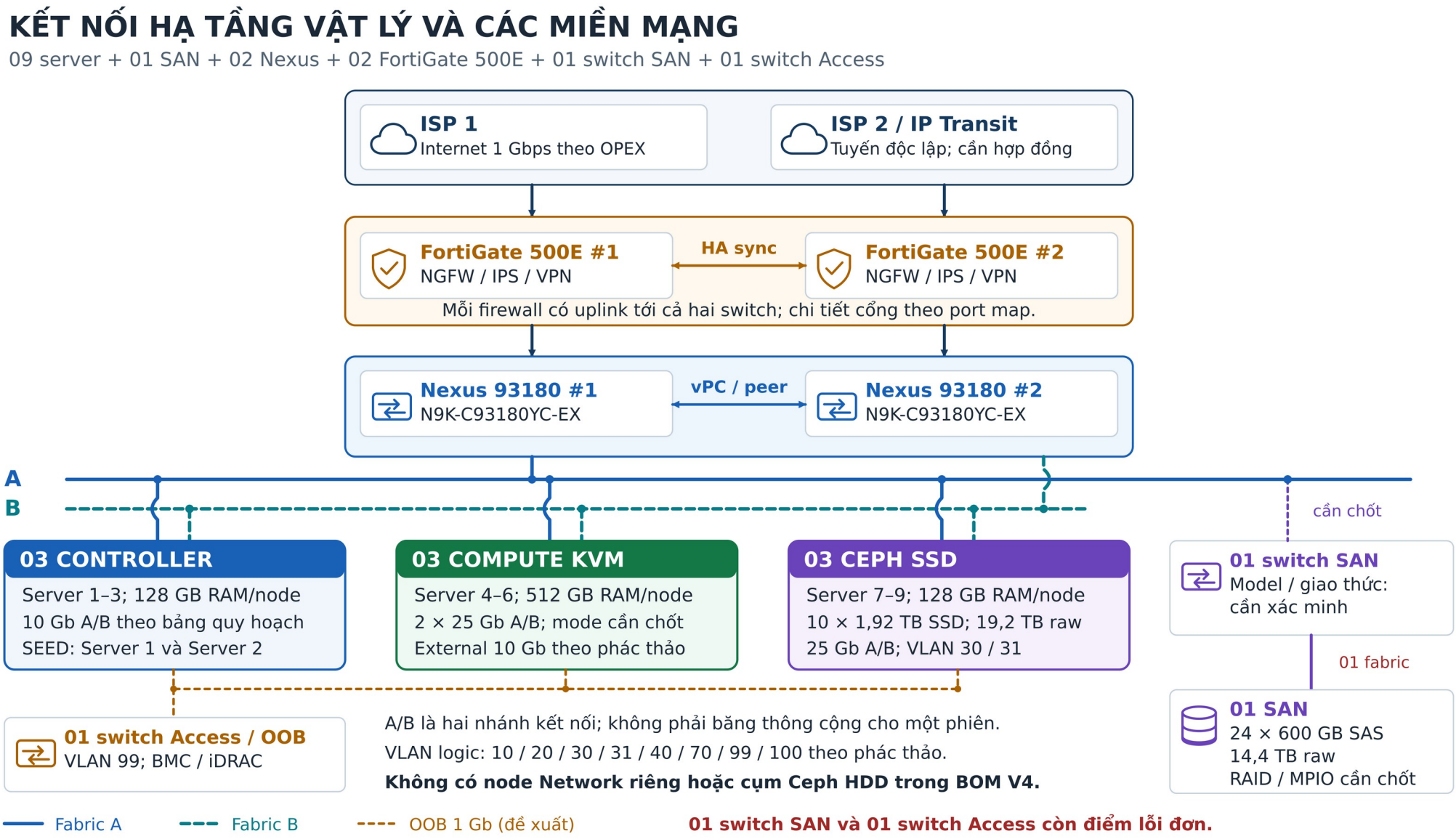
Số lượng thiết bị được đối soát theo sheet Quy Hoạch Hạ Tầng Phần Cứng và Rack_Power của bảng CAPEX/OPEX V4. Quy hoạch VLAN, OOB, luồng quản trị và Portal–API Broker dưới đây là thiết kế đề xuất cần được phê duyệt trước khi cấu hình.

Kiến trúc phân vùng bảo mật



Hình 1. Kiến trúc phân vùng bảo mật và các luồng logic của Hệ thống X-OR SECURE CLOUD

Kết nối vật lý và phân tách mạng



Hình 2. Kết nối hạ tầng giai đoạn 1 theo BOM V4 và quy hoạch mạng đề xuất

Trạng thái kiến trúc: quy mô 09 server + 01 SAN là thiết kế mục tiêu cập nhật, chưa phải as-built hoặc bằng chứng đã đạt Cấp độ 4. Bundle private cloud hiện có 07 node, LVM/no-Ceph, còn cấu hình qemu, registry insecure và IP/domain mẫu. Hồ sơ chính thức phải có bản vẽ, CMDB, port map, cấu hình VLAN/VRF/ACL/NGFW, kiểm thử cô lập tenant, HA, backup/restore và DR thống nhất với thực tế.

4. Danh mục thiết bị giai đoạn 1

Nhóm thiết bị	SL	ID hoặc model	Vai trò và dữ liệu	Kết nối
Controller	03	Server 1–3 / Dell R630	128 GB RAM/node; 2 × 480 GB OS và 2 × 800 GB/node. Server 1–2 kiêm SEED. Dữ liệu 800 GB cần xác nhận vai trò, không tự tính là OSD Ceph.	10 Gb A/B theo bảng; phác thảo 25 Gb cần chốt. VLAN 10/70; OOB 99.
Compute KVM	03	Server 4–6 / Dell R630	512 GB RAM/node; 2 × 480 GB OS/node; workload tenant. Network agent/gateway đồng vị trí là phương án cần phê duyệt.	25 Gb A/B; VLAN 10/20; external 10 Gb và VLAN cần chốt.
Ceph SSD	03	Server 7–9 / Dell R630	128 GB RAM/node; 2 × 480 GB OS/node. OSD SSD phân bổ 4/3/3 × 1,92 TB, tổng 10 ổ; 19,2 TB raw.	25 Gb A/B; VLAN 30 client và 31 cluster theo phác thảo.
SAN	01	Model chưa xác nhận	24 × 600 GB SAS; 14,4 TB raw. Chưa chốt RAID, giao thức, Cinder backend, MPIO hoặc vai trò lưu trữ.	Qua 01 switch SAN theo BOM; fabric dự phòng chưa được chứng minh.
Switch Core	02	Cisco N9K-C93180YC-EX	48 cổng 10/25 GbE và 6 cổng 100 GbE theo BOM. Hai nhánh fabric A/B.	vPC/LACP là phương án; phải chốt port-channel, peer/keepalive, MTU và failover.
Firewall	02	FortiGate 500E	NGFW/IPS/VPN và HA theo thiết kế. Model thay cho 200F trong hồ sơ trước.	Cần BOM cổng, license/support, uplink đôi và kiểm thử HA/state sync.

Nhóm thiết bị	SL	ID hoặc model	Vai trò và dữ liệu	Kết nối
Switch SAN	01	Model/giao thức chưa xác nhận	Thiết bị mạng lưu trữ. Số lượng 01 chưa chứng minh dual fabric.	Điểm lỗi đơn cần xử lý hoặc giới hạn SLA được phê duyệt.
Switch Access	01	Model chưa xác nhận	Đề xuất dùng OOB/BMC/iDRAC VLAN 99, 1 Gb theo phác thảo.	Không định tuyến từ Internet/tenant; có điểm lỗi đơn OOB.

Tổng tài nguyên máy chủ theo cấu hình vai trò là 2.304 GB RAM, không dùng 5.120 GB trong sheet định giá 10 server để mô tả cụm giai đoạn 1. Số ổ OS là 18 × 480 GB. Ceph 19,2 TB raw và SAN 14,4 TB raw không đồng nghĩa dung lượng usable hoặc tài nguyên có thể bán. Phải tính riêng RAID/replica, lệch phân bố OSD 4/3/3, dung lượng dự phòng, failure domain và khả năng rebuild khi mất node.

Vật tư đầu tư theo CAPEX

Hạng mục CAPEX	SL	Lưu ý đối soát
Card NDC 25 Gb	18	Số lượng mua sắm; chưa có phân bổ theo máy/cổng.
Card PCI CX4121A 25 Gb	18	Cần kiểm tra slot, compatibility và ánh xạ NIC–switch.
Card LAN D33682 dual port	09	Đề xuất OOB; xác nhận model/cổng thực tế.
DAC 25 Gb	36	Cần port map, chiều dài và kiểm tra tương thích.
RJ45 3 m	26	Đối soát OOB/BMC, keepalive và các kết nối đồng.
SSD SATA 480 GB OS	18	Hai dòng CAPEX 08 + 10; tương ứng 02 ổ × 09 server.
SSD SATA 1,92 TB data	10	OSD Ceph SSD theo quy hoạch 4/3/3.
Tray ổ cứng / ray server	30 / 15	Số lượng mua sắm; không suy ra số server từ số ray.

5. Phân vùng mạng và luồng dữ liệu

VLAN	Phân vùng đề xuất	Mục đích	Nguyên tắc kiểm soát
10	Internal service / API	Trao đổi nội bộ, control/service và API được cho phép.	Không phơi Internet; allow-list theo nguồn/đích/cổng. Chỉ kết nối VLAN 70 qua rule được duyệt, không mở all-to-all.
20	Tenant overlay	Transport VXLAN/GENEVE/OVN theo mô hình Neutron đã chọn.	Tenant isolation, SG/anti-spoof; tenant không được truy cập underlay/control/OOB. Chốt MTU với overhead thực tế.
30	Ceph client/public	Client I/O của host/dịch vụ cloud tới Ceph SSD.	Ceph public không phải Internet public. Chỉ client Ceph được phép; CephX và giới hạn quyền.
31	Ceph cluster/private	Replication, backfill, recovery và heartbeat Ceph.	Cô lập khỏi tenant/Internet; QoS/MTU; không route theo luồng dịch vụ tenant.
40	Security / administration	Bastion/PAM/MFA, DBF, SIEM và dịch vụ backup trong zone Z6.	Tách quyền và security group/VRF nội vùng; không cho production admin xóa backup/log.
70	OpenStack API private	API đích phía controller sau gateway/broker.	Chỉ broker/gateway và admin được duyệt; service account tối thiểu, TLS, audit, rate limit.
99	OOB / IPMI / iDRAC	Quản trị BMC thiết bị qua switch Access riêng.	1 Gb đề xuất; VPN/MFA/PAM và allow-list; cấm tenant/Internet/direct access.
100	Portal / DMZ	Portal web, public ingress và gateway ở lớp dịch vụ.	WAF SafeLine, TLS; portal gửi yêu cầu tới broker, không gọi thẳng API controller.
Chưa chốt	External/ provider và SAN	Provider/EIP cho VM; VLAN hoặc fabric SAN theo giao thức được chọn.	Không dùng VLAN 30 Ceph làm external. Chốt VLAN/VRF, ACL, gateway/BGP và SAN zoning/MPIO trong thiết kế chi tiết.

Bảng VLAN trên là quy hoạch logic đề xuất theo phác thảo mới, chưa phải cấu hình đã nghiệm thu. Ma trận nguồn–đích–cổng–giao thức–mục đích–owner phải được phê duyệt và

triển khai deny-by-default. Truy cập quản trị từ xa đi qua VPN/MFA trên NGFW, sau đó bastion/PAM tại VLAN 40, rồi mới tới tài nguyên được cấp quyền. OOB VLAN 99 không đi chung đường truy cập tenant.

Các luồng đánh số trên Hình 1

Luồng	Nguồn → đích	Kiểm soát và phạm vi
L1	Z1 → Z2	HTTP/HTTPS Portal/API đi qua NGFW và WAF. WAF không phải thiết bị bắt buộc đi qua cho mọi giao thức provider của VM.
L2	Z2 → Z3	Published tenant/EIP/LB qua NGFW/ACL/SG và gateway được chọn; không mở truy cập vào control hoặc Ceph cluster.
L3	Broker Z2 → API Z4	Portal ingress VLAN 100; broker dùng danh tính riêng và egress tới API private VLAN 70. Chỉ endpoint/cổng được phép; không chuyển tiếp tùy ý.
L4	Z4 → Z3	Controller gọi agent/điều phối theo allow-list trên internal plane. Đây không phải tenant được cấp quyền truy cập controller.
L5	Host/dịch vụ Z3 → Z5	Client I/O tới Ceph VLAN 30; khóa CephX tối thiểu. Không cho guest VM nối trực tiếp Ceph VLAN 31. SAN là backend riêng cần chốt.
L6	Z5 → backup Z6	Backup/replication bằng tài khoản riêng và rule cụ thể; restore chiều ngược chỉ khi được phê duyệt.
L7 / A	Admin → Z6 → Z4/host	VPN + MFA → bastion/PAM → IP quản trị/API/BMC được cho phép. Đường tới VLAN 10/20/30/99 giới hạn theo tác vụ, không route mở toàn VLAN.
Log / DR	Z1–Z5 → SOC; backup → DR	Telemetry qua collector/agent xác thực; immutable log. DR cần site độc lập, hợp đồng và diễn tập RPO/RTO, chưa có bằng chứng.

Điểm cần chốt trước cấu hình và nghiệm thu

Quy hoạch V4 và Rack_Power đều liệt kê 09 server. Sheet Định giá server vẫn để 10 server. Các cột RAID/vai trò và VLAN trong sheet quy hoạch còn nội dung của phương án cũ: Server 4–5 ghi Network, Server 7–8 ghi Compute; đây không phải các server bổ sung.

VLAN 30/40 trong bảng tính cũ có nghĩa external/Ceph SSD, trong ảnh vẽ tay mới có nghĩa Ceph client/security. Hồ sơ dùng quy hoạch đề xuất mới nêu trên; phải lập bảng chuyển đổi, IP plan và rule trước triển khai, không tái sử dụng cấu hình cũ theo số VLAN.

Controller ghi 10 Gb active–passive trong quy hoạch nhưng phác thảo thể hiện 25 Gb A/B. Compute/Ceph có mô tả 25 Gb active–passive và 50 Gb active–active cùng tồn tại. Phải chốt NIC/port-channel và mode theo từng plane; 2 × 25 Gb không đảm bảo một phiên đạt 50 Gb.

Không có node Network độc lập trong BOM. Cần chọn OVN/Neutron, vị trí gateway/agent trên compute hoặc controller, quy tắc scheduler/HA và headroom; kiểm thử mất host/agent, DHCP/metadata/NAT và tác động tới tenant.

01 switch SAN và 01 switch Access là các điểm lỗi đơn cần xử lý hoặc chấp nhận rủi ro có căn cứ. Chưa có model/giao thức SAN, dual fabric, dual controller và MPIO; không kết luận toàn hệ thống hết điểm lỗi đơn.

Ảnh vẽ tay thể hiện một đường ISP, còn OPEX có thêm dòng backup IP Transit/BGP chưa có đơn giá hoặc hợp đồng. Hai ISP độc lập là mục tiêu, không phải bằng chứng đã triển khai. Model FortiGate 500E phải được kiểm tra vòng đời, support/license và hiệu năng với tính năng bảo mật bật.

6. Phụ thuộc và hệ thống liên quan

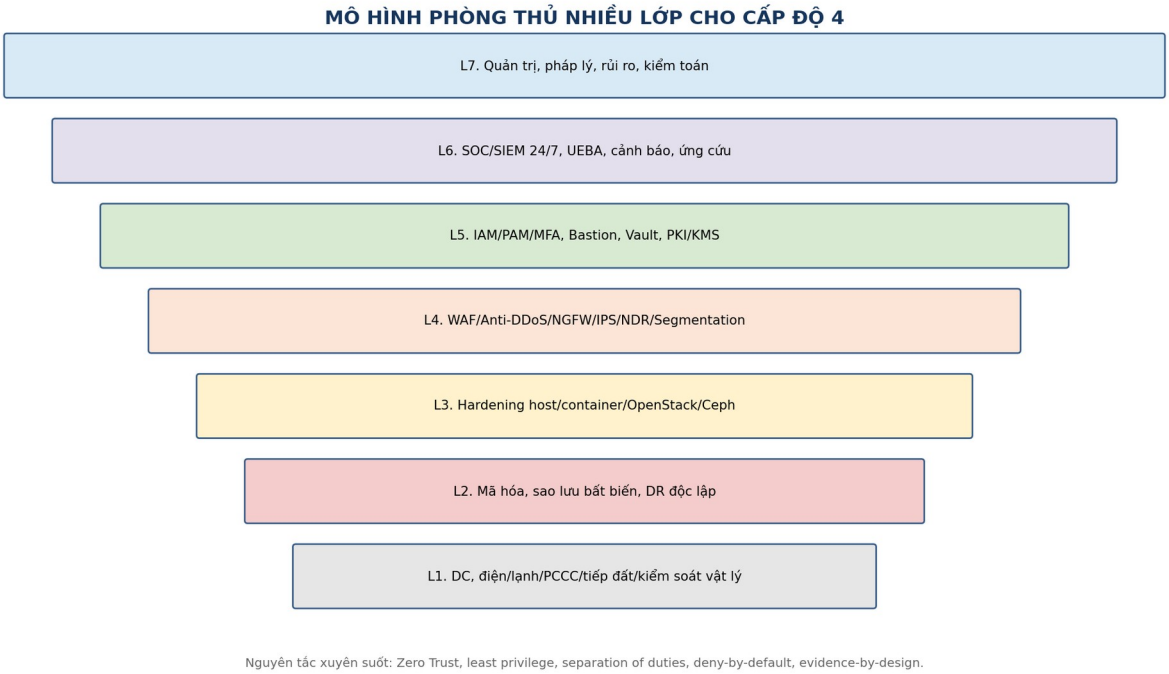
Hệ thống/phụ thuộc	Quan hệ	Rủi ro lan truyền	Biện pháp
IDC/Colocation	Điện, lạnh, không gian rack, PCCC, access, BMS/DCIM	Mất site hoặc lỗi MEP làm dừng toàn bộ cụm	A/B feed; UPS/máy phát; TCCF; MOP/SOP/EOP; DR site độc lập.
ISP/Carrier 1-2	Kết nối Internet và BGP	Mất carrier hoặc route hijack	Hai tuyến/nhà mạng độc lập; RPKI/route-filter; failover test.
DNS/NTP/PKI/KMS	Định danh, thời gian, chứng thư và khóa	Gián đoạn auth/log; giả mạo; mất khả năng giải mã	HA; nguồn thời gian tin cậy; HSM/KMS; backup khóa; rotation.
SOC/SIEM/NOC	Giám sát, cảnh báo, ứng cứu	Mất quan sát; phản ứng chậm	Out-of-band telemetry; queue/buffer; HA; trực 24/7.
Backup/DR	Phục hồi dữ liệu và dịch vụ	Ransomware; mất site; bản sao hỏng	3-2-1-1-0; immutable/offline; site độc lập; restore/DR drill.
CI/CD và registry	Cung ứng image/container/config	Supply-chain compromise; CVE; secret trong image	Ký image/SBOM; scan gate; secret scan; private registry TLS; immutable digest.
Tenant systems	Sử dụng hạ tầng và dữ liệu	Lateral movement; abuse; noisy neighbor	Isolation; quota; anti-spoofing; security group; shared

Hệ thống/phụ thuộc	Quan hệ	Rủi ro lan truyền	Biện pháp
			responsibility.

PHẦN III

Tài liệu thiết kế sơ bộ và yêu cầu kỹ thuật

1. Nguyên tắc thiết kế Cấp độ 4



Hình 3. Mô hình phòng thủ nhiều lớp

- Mục tiêu loại bỏ điểm lỗi đơn ở các thành phần trọng yếu. BOM hiện còn 01 switch SAN và 01 switch Access; phải bổ sung dự phòng hoặc phê duyệt giới hạn rủi ro/SLA trước nghiệm thu, không kết luận chỉ từ bản vẽ.
- Tách control plane, data plane, management plane, storage plane và tenant plane bằng VLAN/VRF/ACL; áp dụng micro-segmentation tại lớp workload.
- Mọi truy cập quản trị đi qua định danh mạnh, MFA, PAM/bastion, ghi phiên và phê duyệt theo vai trò; cấm tài khoản dùng chung không truy vết.
- Cấu hình chuẩn được quản lý như mã nguồn, phê duyệt thay đổi, kiểm tra drift và có phương án rollback.
- Image/container phải có nguồn gốc, SBOM, ký số/xác minh digest, không chứa secret/key và vượt qua release gate trước production.
- Telemetry bảo mật được chuyển tới SIEM gần thời gian thực; đồng bộ thời gian; chống sửa/xóa; lưu trữ theo chính sách và yêu cầu pháp luật.
- Sao lưu theo 3-2-1-1-0, có bản sao bất biến/offline và DR site độc lập; kiểm thử phục hồi và chuyển vùng theo RPO/RTO đã phê duyệt.

2. Thiết kế HA và khả năng chịu lỗi

Lớp	Thiết kế mục tiêu	Điểm kiểm thử nghiệm thu
Nguồn điện/DC	Dual PSU về hai PDU/feed độc lập; UPS và máy phát theo site; bảo trì đồng thời	Rút từng feed/PDU theo MOP; xác nhận không gián đoạn; hồ sơ TCCF hoặc tương đương.
Network switching	02 Nexus N9K-C93180YC-EX, vPC/peer-link theo thiết kế; bonding active–backup hoặc LACP theo từng plane, chưa chốt mode từ BOM.	Fail từng switch/uplink; kiểm tra convergence, LACP, MTU, packet loss.
Firewall/edge	02 FortiGate 500E HA theo BOM V4; state/session sync; chính sách versioned; cần kiểm tra support/license và hiệu năng.	Fail active node; session persistence; rollback policy; HA split-brain test.
Control plane	03 controller; quorum; API VIP; database/message queue HA	Tắt từng controller; kiểm tra API, DB quorum, message queue, scheduler.
Network plane	Không có 02 Network node riêng. Chọn network agent/gateway đồng vị trí trên 09 server, có HA và headroom theo thiết kế được duyệt.	Fail host/agent/gateway; north-south, DHCP/metadata/NAT/LB continuity; chứng minh placement và khả năng chịu lỗi.
Compute	03 compute KVM; anti-affinity; evacuation theo chính sách	Mất 01 compute; evacuation/rebuild; capacity N+1; tenant notification.
Ceph	03 Ceph SSD, tổng 10 OSD 1,92 TB phân bố 4/3/3; replica/failure domain theo thiết kế. 01 SAN là backend riêng; không có Ceph HDD trong BOM V4.	Mất OSD/host; recovery/backfill khi lệch dung lượng; đo usable/latency. SAN: mất path/controller/fabric, MPIO; 01 switch SAN cần xử lý SPOF.
Monitoring/ SOC	HA collector/queue/storage; cảnh báo đa kênh	Mất collector; log buffering; alert delivery; time sync.
DR	Site độc lập về rủi ro; bản sao cấu hình/dữ liệu; runbook	DR drill; đo RPO/RTO; DNS/BGP/identity dependency; quyết định failback.

3. Yêu cầu cấu hình an toàn nền tảng

Thành phần	Yêu cầu cấu hình tối thiểu
Ubuntu 24.04	CIS-aligned hardening; Secure Boot/TPM khi hỗ trợ; chỉ gói cần

Thành phần	Yêu cầu cấu hình tối thiểu
LTS/host OS	thiết; SSH key + MFA qua bastion; auditd; EDR/HIDS; FIM; patch ring; cấm direct root.
KVM/libvirt	Dùng KVM thay qemu emulation; sVirt/AppArmor/SELinux phù hợp; giới hạn device passthrough; live migration mã hóa và chỉ qua mạng quản trị.
Kolla/containers	Rootless/non-root khi khả thi; read-only FS; drop capabilities; seccomp/AppArmor; resource limits; không bind host socket tùy tiện; signed images.
OpenStack Keystone	Federation/SSO nếu có; MFA cho admin; application credentials; domain/project separation; token TTL; audit admin actions.
Nova	Dedicated host aggregate cho workload đặc biệt; anti-affinity; metadata protection; console TLS; image verification; quota.
Neutron/OVN/OVS	Port security; anti-spoofing; security group deny; DHCP/RA guard; provider network separation; flow monitoring; no flat admin exposure.
Glance	Private image visibility mặc định; scan/sign/SBOM; immutable digest; lifecycle và provenance; cấm embedded credential.
Cinder/Ceph	CephX; keyring least privilege; encryption-at-rest cho volume cần bảo vệ; secure delete/crypto erase; backup; pool/tenant isolation.
Horizon/Portal/API	TLS 1.2+; HSTS/CSP/cookie secure; WAF; rate limit; session timeout; CAPTCHA/risk-based auth; SAST/DAST.
Registry/repository	TLS bắt buộc; không insecure registry; RBAC; vulnerability gate; retention; signing; audit; offline mirror cho air-gap.

4. Tiêu chí nghiệm thu thiết kế

1. Toàn bộ sơ đồ logical/physical, IP plan, VLAN/VRF, port map, rack elevation và data-flow được phê duyệt, thống nhất tên thiết bị và model.
2. Không còn IP, domain, certificate hoặc credential mẫu trong production; secrets được quản lý bằng Vault/KMS/HSM và rotation.
3. Release gate image/container PASS; khắc phục toàn bộ Critical có bản vá và High theo SLA; không còn SSH host private key trong image.
4. Pentest độc lập bao phủ portal/API, control plane exposed surfaces, tenant isolation và retest; không còn phát hiện Critical/High chưa được chấp nhận rủi ro đúng thẩm quyền.
5. Kiểm thử HA, failover, backup/restore, ransomware recovery và DR có biên bản, số đo RTO/RPO và phê duyệt.
6. Hồ sơ DC site hiện hành chứng minh tuân thủ TT42/2025/TT-BKHCN, điện/lạnh/PCCC/tiếp đất/access/CCTV, bảo trì đồng thời và SLA.

PHẦN IV

Thuyết minh đề xuất Cấp độ 4

1. Nguyên tắc xác định cấp độ

Việc xác định cấp độ dựa trên chức năng, phạm vi phục vụ, loại thông tin được xử lý, hậu quả khi mất an ninh mạng và kết quả đánh giá rủi ro; không dựa đơn thuần vào tên gọi "Public Cloud", số lượng thiết bị, chứng chỉ của trung tâm dữ liệu hoặc mong muốn thương mại.

Điều kiện tiên quyết: Chủ quản HTTT phải chọn và chứng minh ít nhất một tiêu chí Cấp độ 4 tại Điều 14 Nghị định 331/2026/NĐ-CP. Nếu chỉ là nền tảng cloud thương mại thông thường, chưa chứng minh phạm vi toàn quốc/24x7 theo tiêu chí pháp lý hoặc chưa có kết quả đánh giá rủi ro tương ứng, không đủ cơ sở kết luận Cấp độ 4.

2. Ma trận lập luận đề xuất

Tiêu chí Cấp độ 4	Khả năng áp dụng cho X-OR SECURE CLOUD	Bằng chứng bắt buộc
Xử lý BMNN hoặc phục vụ quốc phòng, an ninh; bị phá hoại gây tổn hại nghiêm trọng tới an ninh quốc gia	Chỉ áp dụng nếu có quyết định nhiệm vụ, phạm vi dữ liệu và đánh giá hậu quả tương ứng. Không mặc định.	Quyết định giao nhiệm vụ; danh mục BMNN; phương án cơ yếu; đánh giá tác động/an ninh quốc gia.
HTTT quốc gia phục vụ phát triển Chính phủ điện tử hoặc hạ tầng thông tin phục vụ cơ quan, tổ chức trên phạm vi toàn quốc; yêu cầu 24/7 và không chấp nhận dừng ngoài kế hoạch	Có thể là căn cứ nếu hệ thống thực sự phục vụ phạm vi toàn quốc và tính liên tục là yêu cầu nghiệp vụ bắt buộc, không chỉ là SLA thương mại.	Danh mục khách hàng/phạm vi; quyết định chủ quản; yêu cầu nghiệp vụ 24/7; BIA; SLA; số liệu tác động khi gián đoạn.
HTTT điều khiển công nghiệp phục vụ công trình xây dựng cấp I	Không phù hợp với mô hình X-OR SECURE CLOUD hiện mô tả, trừ khi phạm vi hệ thống thay đổi.	Hồ sơ phân cấp công trình và chức năng điều khiển trực tiếp.
Hệ thống khác do Thủ tướng Chính phủ quyết định	Chỉ áp dụng khi có quyết định cụ thể.	Quyết định của Thủ tướng Chính phủ.
Hệ thống được đánh giá rủi ro theo Khung quản lý rủi ro ANM	Có thể áp dụng sau đánh giá chính thức và kết luận của cơ quan có thẩm quyền.	Báo cáo đánh giá rủi ro; phương pháp/khung; ý kiến chuyên môn; kết luận thẩm định.

3. Đề xuất câu chữ sau khi đủ bằng chứng

“Hệ thống X-OR SECURE CLOUD được đề xuất Cấp độ 4 theo [điểm/khoản/Điều 14 Nghị định 331/2026/NĐ-CP], do [mô tả chính xác phạm vi, chức năng, dữ liệu và yêu cầu 24/7]. Khi hệ thống bị tấn công, phá hoại hoặc gián đoạn, hậu quả dự kiến gồm [mô tả định lượng/định tính đã được BIA và đánh giá rủi ro phê duyệt]. Căn cứ kèm theo gồm [danh mục quyết định, BIA, risk report, SLA, phạm vi người dùng và ý kiến chuyên môn].”

4. Ranh giới giữa Cấp độ HTTT và Tier/Rating DC

Cấp độ 4 là cấp độ an ninh mạng của hệ thống thông tin; Tier III/TCDD/TCCF hoặc Rating của trung tâm dữ liệu là bằng chứng về năng lực thiết kế/xây dựng/vận hành DC và không thay thế hồ sơ xác định cấp độ. Hệ thống vẫn phải đáp ứng đầy đủ kiểm soát quản lý, kỹ thuật, vận hành, dữ liệu, pháp lý và ứng cứu trong phạm vi do mình kiểm soát.

PHẦN V

Báo cáo đánh giá rủi ro an ninh mạng chi tiết

1. Phương pháp đánh giá

Mẫu sử dụng thang 5x5. Khả năng xảy ra (L) và mức tác động (I) chấm từ 1 đến 5; mức rủi ro R = L × I. Ngưỡng: 1-4 Thấp; 5-9 Trung bình; 10-15 Cao; 16-25 Rất cao. Điểm tồn dư chỉ được xác nhận sau khi kiểm soát đã triển khai và có bằng chứng kiểm thử.

Mức	Khả năng xảy ra	Tác động
1	Hiếm; chưa ghi nhận và khó xảy ra trong điều kiện hiện tại	Không đáng kể; không ảnh hưởng SLA/dữ liệu
2	Ít khả năng; có thể xảy ra nhưng cần nhiều điều kiện	Nhỏ; ảnh hưởng cục bộ, phục hồi trong ngưỡng
3	Có thể; đã có tiền lệ trong ngành	Đáng kể; gián đoạn/dữ liệu bị ảnh hưởng có kiểm soát
4	Khả năng cao; bề mặt tấn công/phơi nhiễm rõ	Nghiêm trọng; vi phạm SLA/pháp lý, nhiều tenant
5	Gần như chắc chắn hoặc đang bị khai thác	Rất nghiêm trọng; diện rộng, kéo dài, ảnh hưởng ANQG/xã hội nếu thuộc phạm vi

ID	Kịch bản	Nhóm	L	I	R	Xử lý bắt buộc	Lr	Ir	Rr	Owner
R01	Rò rỉ khóa/secret trong image hoặc repository	Supply chain/credential	5	5	25	Loại bỏ key; rotate toàn bộ; secret scan; ký image; release gate	2	5	10	CISO/ DevSecOps
R02	Khai thác Critical/High CVE trong container OpenStack	Vulnerability/RCE	5	5	25	Patch/SBOM/ scan; canary; compensating control; retest	2	5	10	Platform/ Security
R03	Tenant escape hoặc lỗi cách ly đa thuê	Virtualization	3	5	15	KVM hardening; upstream patch; security review; isolation pentest	1	5	5	Platform/ Security
R04	Chiếm quyền tài khoản quản trị cloud	IAM	4	5	20	MFA/PAM/ bastion; JIT; session	1	5	5	IAM/SOC

ID	Kịch bản	Nhóm	L	I	R	Xử lý bắt buộc	Lr	Ir	Rr	Owner
						recording; SoD; alert				
R05	DDoS làm gián đoạn portal/API và dịch vụ tenant	Availability	4	5	20	Anti-DDoS hai lớp; WAF/rate limit; autoscale; runbook	2	5	10	NetSec/SOC
R06	Mất một carrier/Internet	Dependency	4	4	16	Hai ISP độc lập; BGP; route policy; failover drill	1	4	4	Network
R07	Sai cấu hình firewall/ACL gây lộ management	Misconfiguration	4	5	20	IaC; peer review; policy-as-code; drift; pre/post test	1	5	5	NetSec
R08	Mất quorum control plane/database/message queue	HA	3	5	15	3 controller; quorum monitor; fencing; backup; failover test	1	5	5	Cloud Ops
R09	Ceph corruption/mất dữ liệu hoặc degraded kéo dài	Storage	3	5	15	Failure domain; replica; scrub; health alerts; capacity reserve; backup	1	5	5	Storage
R10	Ransomware phá hủy production và backup online	Malware	4	5	20	EDR; immutable backup; offline copy; MFA delete; restore test	1	5	5	SOC/ Backup
R11	Mất toàn bộ DC/site	Physical/ BCP	2	5	10	DR site độc lập; replicated backup; DR runbook/drill	1	5	5	BCM/Cloud Ops
R12	Lỗi nguồn/lạnh/PCCC tại IDC	Physical	3	5	15	A/B feed; UPS/generator; cooling redundancy;	1	5	5	DC provider

ID	Kịch bản	Nhóm	L	I	R	Xử lý bắt buộc	Lr	Ir	Rr	Owner
						TCCF/MOP evidence				
R13	Log bị xóa/sửa hoặc giám sát mù	Detection	4	4	16	Remote immutable log; HA SIEM; time sync; health monitoring	1	4	4	SOC
R14	Lạm dụng nội bộ/nhà cung cấp	Insider	3	5	15	SoD; PAM/JIT; background check; DLP; audit; exit process	1	5	5	HR/CISO
R15	Rò rỉ dữ liệu cá nhân tenant	Privacy	3	5	15	DPA; encryption; minimization; access control; breach process	1	5	5	DPO/Legal
R16	DNS/BGP hijack hoặc route leak	Network	3	5	15	RPKI/ROA; prefix filters; max-prefix; DNSSEC; monitoring	1	5	5	Network
R17	Chứng thư/khóa hết hạn hoặc mất khóa	Crypto	3	4	12	PKI inventory; auto-renew; KMS/HSM; dual control; backup/rotation	1	4	4	PKI/IAM
R18	Rollback/upgrade OpenStack thất bại	Change	3	5	15	Lab/canary; compatibility matrix; backup; staged rollout; rollback	1	5	5	Platform/ Change
R19	Noisy neighbor/cạn tài nguyên	Capacity	4	4	16	Quota; reservations; telemetry; N+1; forecasting; QoS	2	4	8	Capacity
R2	Không đủ bằng	Compliance	4	4	16	Evidence	1	4	4	GRC/Legal

ID	Kịch bản	Nhóm	L	I	R	Xử lý bắt buộc	Lr	Ir	Rr	Owner
0	chứng DC hoặc hồ sơ cấp độ					register; contract clauses; annual refresh; audit trail				

Lưu ý điểm tồn dư: Các điểm Lr/Ir/Rr trong bảng là mục tiêu thiết kế, không phải kết quả đã kiểm chứng. Hội đồng rủi ro phải xác nhận lại sau triển khai, pentest, HA/DR drill và nghiệm thu bằng chứng.

2. Kế hoạch xử lý rủi ro ưu tiên

Ưu tiên	Hành động	Điều kiện hoàn thành
P0-01	Đóng toàn bộ SSH private key trong image và xoay khóa	Không còn key trong image/history; credential cũ vô hiệu; scan lại PASS.
P0-02	Khắc phục Critical có bản vá và tối đa High theo SLA	SBOM + Trivy/scan độc lập; release gate PASS; ngoại lệ có risk acceptance.
P0-03	Chốt thiết kế và as-built 09 server + 01 SAN theo BOM V4, topology nhất quán	Bản vẽ, CMDB, serial, port map, IP/VLAN, model firewall thống nhất.
P0-04	Thiết lập hai ISP/BGP và kiểm thử failover	Diverse path; BGP policy; biên bản failover đạt SLA.
P0-05	Bổ sung DR site độc lập và backup bất biến	BIA/RTO/RPO; hợp đồng site; replication; restore/DR drill.
P0-06	Thu đủ bằng chứng DC hiện hành	TT42/TCCF; A/B; UPS/gen; PCCC; grounding; cooling; BMS/DCIM; access/CCTV.
P0-07	Pentest độc lập và tenant-isolation test	Bao phủ portal/API/control exposure; retest; không còn Critical/High mở.
P0-08	Hoàn thiện căn cứ pháp lý Cấp độ 4	Chọn tiêu chí Điều 14; BIA/risk report; ý kiến chuyên môn; thẩm định/phê duyệt.

PHẦN VI

Thuyết minh phương án bảo đảm an ninh mạng Cấp độ 4

1. Quản trị, pháp lý và hồ sơ cấp độ

- Ban hành quy chế bảo đảm ANM áp dụng toàn vòng đời: thiết kế, phát triển, triển khai, vận hành, thay đổi, ứng cứu, nâng cấp và hủy bỏ.
- Thiết lập Hội đồng/RACI với separation of duties giữa chủ quản, vận hành, chuyên trách ANM, thẩm định và kiểm toán; mọi ngoại lệ phải có thời hạn, owner và risk acceptance.
- Duy trì hồ sơ cấp độ theo configuration baseline; đánh giá lại khi thay đổi phạm vi, dữ liệu, kết nối, chức năng, quy mô hoặc sau sự cố nghiêm trọng.
- Hợp đồng cloud/colo phải có SLA, DPA, shared responsibility, quyền kiểm tra, thông báo sự cố, quản lý nhà thầu phụ, thu hồi/xóa dữ liệu và hỗ trợ điều tra.

2. Quản lý tài sản, cấu hình và thay đổi

- CMDB là nguồn dữ liệu chuẩn cho thiết bị, phần mềm, image, API, chứng thư, license, owner, EOL/EOS và quan hệ phụ thuộc; đồng bộ discovery và đối soát định kỳ.
- Cấu hình chuẩn hóa bằng Ansible/IaC, lưu Git có ký/approval; baseline hardening được kiểm tra tự động; drift tạo ticket và SLA khắc phục.
- Thay đổi production theo ITSM: RFC, phân tích tác động/rủi ro, peer review, CAB, backup, kế hoạch rollback, maintenance window, xác nhận hậu kiểm.

3. IAM, PAM và kiểm soát đặc quyền

- Định danh duy nhất; SSO/federation; MFA bắt buộc cho admin, VPN, portal quản trị và thao tác phá hủy; tài khoản dịch vụ không đăng nhập tương tác.
- PAM cung cấp JIT/JEA, vaulting/rotation, approval và ghi phiên. Break-glass có niêm phong điện tử, cảnh báo tức thời, kiểm tra sau sử dụng.
- RBAC theo least privilege; review quyền tối thiểu hàng quý và khi thay đổi nhân sự; thu hồi ngay khi nghỉ việc/chuyển vai trò.
- Khóa SSH, API token, application credential, Ceph keyring và secret Kolla được quản lý tập trung; không hard-code trong image, Git hoặc log.

4. An ninh mạng và phòng thủ biên

- Hai ISP độc lập, BGP có prefix/max-prefix/filter, RPKI/ROA khi khả dụng; chống route leak/hijack; giám sát SLA và diễn tập failover.
- Anti-DDoS upstream kết hợp on-prem/cloud scrubbing; NGFW/IPS HA; WAF cho portal/API; rate limiting, bot/API protection và threat intelligence.
- Phân vùng DMZ, management, control, tenant, storage, backup, SOC; deny-by-default; ACL/micro-segmentation; north-south và east-west visibility.
- VPN có MFA, bastion/PAM; cấm công bố BMC, SSH, database và control API ra Internet; OOB management độc lập khi khả thi.

5. An toàn máy chủ, ảo hóa và nền tảng OpenStack

- Host OS LTS được harden, patch, EDR/HIDS/FIM, auditd và secure logging; KVM/sVirt cô lập VM; tắt service/device không dùng.
- OpenStack service endpoints dùng TLS; Keystone token, role/domain/project và service account được tối thiểu hóa; admin actions chuyển SIEM.
- Nova/Neutron/Glance/Cinder/Horizon được cấu hình theo nguyên tắc secure-by-default; metadata, console, image, quota, anti-spoofing và security group được kiểm soát.
- Đánh giá tenant escape, cross-project access, quota bypass, metadata SSRF, image poisoning và abuse API trong pentest/red-team có kiểm soát.

6. An toàn container, chuỗi cung ứng và DevSecOps

- Registry private bắt buộc TLS và RBAC; ký image và xác minh digest; SBOM cho từng release; pin version; provenance và reproducible build khi khả thi.
- Pipeline có SAST, SCA, secret scan, IaC scan, container scan, DAST và approval gate; Critical có bản vá phải chặn release.
- Không nhúng SSH host private key, mật khẩu, token hoặc certificate private key vào image. Phát sinh secret tại triển khai và rotate khi nghi ngờ lộ.
- Air-gap/offline mirror chỉ là biện pháp bù trừ, không thay thế vá. Gói chuyển vùng air-gap phải ký, kiểm hash và có chain-of-custody.

7. An toàn dữ liệu, mã hóa và quản lý khóa

- Phân loại dữ liệu; xác định owner, mục đích, retention, vị trí lưu, luồng chia sẻ và yêu cầu xóa; tách metadata nền tảng và dữ liệu tenant.
- TLS 1.2+ cho dữ liệu truyền; mã hóa volume/object/backup theo phân loại; KMS/HSM, dual control, rotation, backup khóa và crypto-erasure.
- DLP/egress control cho vùng quản trị; chống snapshot/image public ngoài ý muốn; secure wipe khi thu hồi disk/volume; chứng từ tiêu hủy thiết bị.
- Tuân thủ Luật Bảo vệ dữ liệu cá nhân; DPA; hỗ trợ quyền chủ thể, đánh giá tác động xử lý/chuyển dữ liệu khi áp dụng; thông báo vi phạm theo pháp luật.

8. Nhật ký, giám sát và SOC 24/7

- Thu log từ firewall/WAF/IPS, switch/router, BMC, OS, auditd, EDR, Kolla/container, Keystone, Nova, Neutron, Glance, Cinder, Ceph, portal/API, PAM, backup và CI/CD.
- Đồng bộ NTP tin cậy; log chuyển xa, bất biến/WORM, kiểm soát truy cập, mã hóa và giám sát pipeline; định nghĩa retention theo pháp luật và điều tra.
- SIEM use case bao phủ brute force, impossible travel, privilege escalation, policy change, security group mở rộng, snapshot/image sharing, key access, backup deletion, DDoS và lateral movement.
- SOC trực 24/7 theo playbook; severity, SLA triage/escalation, chain-of-custody và phối hợp NOC/Cloud Ops/Legal/DPO.

9. Quản lý lỗ hổng, bản vá và kiểm thử

- Inventory/CVE correlation theo SBOM; scan host, container, image guest, web/API, external surface và configuration; không coi Trivy là pentest.
- SLA khắc phục theo mức độ; emergency patch; compatibility lab/canary; ngoại lệ có biện pháp bù trừ và thời hạn; quét lại xác nhận.
- Pentest độc lập tối thiểu trước go-live, sau thay đổi lớn và định kỳ; retest bắt buộc; quy tắc kiểm thử bảo vệ tenant/sản xuất.
- Đánh giá đặc biệt cho hypervisor escape, OpenStack RBAC, API authorization, network isolation, Ceph access, backup restore và DR.

10. Sao lưu, liên tục kinh doanh và DR

- BIA xác định dịch vụ trọng yếu, MTPD, RTO, RPO, dependency và capacity; SLA khách hàng không được cao hơn năng lực đã kiểm chứng.
- Áp dụng 3-2-1-1-0: ít nhất 3 bản, 2 loại lưu trữ, 1 offsite, 1 immutable/offline, 0 lỗi sau verify; tách credential và network backup.
- DR site phải độc lập rủi ro vật lý; sao chép cấu hình, database, image, volume/backup theo phân loại; runbook DNS/BGP/PKI/IAM và tenant communication.
- Restore test hàng quý cho mẫu dữ liệu; DR drill tối thiểu hàng năm hoặc theo rủi ro; ghi RTO/RPO thực tế, vấn đề và corrective action.

11. Ứng cứu sự cố và điều tra số

- IRP phân loại sự cố, chỉ huy, đầu mối kỹ thuật/pháp lý/truyền thông, escalation, nghĩa vụ báo cáo và mẫu thông báo khách hàng.
- Playbook cho account takeover, ransomware, DDoS, data breach, supply-chain, tenant escape, insider, BGP/DNS và mất site.
- Bảo toàn chứng cứ: time sync, hash, chain-of-custody, snapshot forensic, log bất biến, thẩm quyền thu thập và bảo vệ dữ liệu cá nhân.
- Diễn tập tabletop và kỹ thuật; post-incident review; cập nhật risk register, baseline, detection và hồ sơ cấp độ.

12. Trung tâm dữ liệu và an ninh vật lý

- Hồ sơ site phải chứng minh công bố/tuân thủ hiện hành theo Thông tư 42/2025/TT-BKHCN và tiêu chuẩn/quy chuẩn áp dụng; không dùng chứng chỉ hết hạn hoặc sai phạm vi site.
- Điện A/B, UPS, máy phát, nhiên liệu, ATS/STS, dual PSU; cooling redundancy; leak detection; PCCC; chống sét/tiếp đất; BMS/DCIM; bảo trì đồng thời.
- Access theo zone, least privilege, 2FA/biometric khi phù hợp, visitor escort, CCTV retention, door alarm, rack lock/seal và nhật ký thao tác.
- Yêu cầu TCCF hoặc bằng chứng vận hành/bảo trì đồng thời tương đương; MOP/SOP/EOP; lịch test tải, máy phát, pin, PCCC và diễn tập.

13. Nhân sự, nhà cung cấp và kiểm toán

- Kiểm tra nhân sự theo vai trò, NDA, đào tạo bắt buộc, cam kết đạo đức, phân quyền và quy trình joiner-mover-leaver.
- Nhà cung cấp được đánh giá rủi ro, ràng buộc SLA/ANM/DPA, quản lý subcontractor, quyền audit, thông báo sự cố và exit/portability.
- Đánh giá tuân thủ định kỳ, kiểm toán độc lập, KPI/KRI, remediation tracking; bằng chứng được lưu có version, owner, ngày hiệu lực và hash/ký số.

14. Mô hình trách nhiệm chia sẻ

Miền kiểm soát	Công ty Cổ phần XOR CLOUD (đơn vị vận hành)	Khách hàng/tenant	DC/nhà cung cấp
DC vật lý	Thu thập bằng chứng, giám sát SLA, phối hợp sự cố	Xác định yêu cầu site nếu workload đặc thù	Điện/lạnh/PCCC/access/CCTV/rack/MEP
Hạ tầng cloud	Thiết kế, hardening, patch, HA, capacity, log, backup nền tảng	Cấu hình dịch vụ đúng hướng dẫn; quản lý quota	Hỗ trợ phần colo/kết nối theo hợp đồng
Guest OS/app	Theo gói managed service nếu có	Patch/hardening/app IAM/log/data/backup nếu không mua managed	Không áp dụng
Dữ liệu cá nhân	Nghĩa vụ bên xử lý/kiểm soát theo vai trò hợp đồng; bảo vệ nền tảng	Xác định mục đích/cơ sở xử lý, quyền chủ thể, retention	Bảo vệ môi trường vật lý
Ứng cứu	SOC nền tảng, containment, điều tra phạm vi cloud, thông báo	Ứng cứu app/data và phối hợp cung cấp chứng cứ	Ứng cứu site/MEP/access
Hồ sơ cấp độ	Cung cấp evidence cloud/DC, vận hành platform controls	Chủ quản hệ thống thuê chịu trách nhiệm hồ sơ của hệ thống mình	Cung cấp chứng cứ kế thừa theo hợp đồng

PHẦN VII

Kế hoạch triển khai, nghiệm thu và duy trì

1. Lộ trình đóng khoảng trống

Giai đoạn	Thời lượng tham chiếu	Công việc chính	Cổng quyết định
G0 - Governance	2-3 tuần	Chốt chủ quản/vận hành; ranh giới; tiêu chí Cấp độ 4; RACI; hồ sơ đầu tư; risk workshop.	Phê duyệt phạm vi và căn cứ cấp độ.
G1 - Thiết kế chi tiết	3-5 tuần	As-designed network/security/compute/Ceph/DC/DR; IP/port/rack; BOM; test plan.	Design review; traceability 129 controls.
G2 - Triển khai nền	4-8 tuần	09 server + 01 SAN; firewall/core A/B, KVM, Ceph SSD, OpenStack, network đồng vị trí được duyệt, IAM/PAM, logging, backup.	Configuration baseline; no sample secrets/domain.
G3 - Security hardening	3-5 tuần	CVE remediation, registry TLS, signed images, SOC use cases, DLP/EDR, WAF/Anti-DDoS.	Release gate PASS.
G4 - Kiểm thử	2-4 tuần	Functional, performance, HA, failover, restore, DR, pentest, retest, tenant isolation.	Không còn Critical/High mở không được phê duyệt.
G5 - Hồ sơ/thẩm định	Theo NĐ 331	Ý kiến chuyên môn; gửi thẩm định; giải trình; chủ quản phê duyệt.	Quyết định phê duyệt cấp độ.
G6 - Go-live/duy trì	Liên tục	Production acceptance; SOC/NOC 24/7; KPI/KRI; audit; reassessment.	Biên bản go-live và review định kỳ.

Thời gian thẩm định Cấp độ 4 theo thông tin công bố về Nghị định 331/2026/NĐ-CP tối đa 25 ngày làm việc kể từ khi nhận đủ hồ sơ hợp lệ; thời gian phê duyệt tối đa 07 ngày làm việc. Tiến độ nội bộ phải cộng thời gian bổ sung/giải trình hồ sơ.

2. Bộ tiêu chí nghiệm thu tối thiểu

Mã	Hạng mục	Tiêu chí pass
AC-01	As-built thống nhất	CMDB, sơ đồ, rack/port map, IP/VLAN, model firewall, serial và cấu hình khớp thực tế.
AC-02	HA control/network/storage	Fail từng node/link/device không gây gián đoạn vượt SLA; có log và số đo.

Mã	Hạng mục	Tiêu chí pass
AC-03	CVE/secret gate	Scan đủ phạm vi; Critical có bản vá = 0; secret/key = 0; ngoại lệ High được phê duyệt.
AC-04	IAM/PAM	MFA/PAM/JIT/session recording; break-glass test; review quyền.
AC-05	Logging/SOC	Nguồn log trọng yếu đầy đủ; time sync; immutability; use case và escalation test.
AC-06	Backup/restore	Restore mẫu VM/volume/config/database đạt RPO/RTO; immutable copy không thể xóa bởi production admin.
AC-07	DR	Diễn tập mất site hoặc tabletop + technical drill; đo RTO/RPO; dependency runbook.
AC-08	Pentest	Independent pentest + retest; bao phủ API/portal/tenant isolation; closure evidence.
AC-09	DC evidence	TT42/TCCF/MEP/PCCC/grounding/cooling/BMS/access/CCTV/MOP-SOP-EOP còn hiệu lực và đúng site.
AC-10	Legal/operational	Hồ sơ cấp độ, SLA/DPA/shared responsibility, IR/BCP, on-call và đào tạo được phê duyệt.

PHỤ LỤC A

Mẫu ý kiến chuyên môn của đơn vị chuyên trách an ninh mạng

[TÊN ĐƠN VỊ CHUYÊN TRÁCH AN NINH MẠNG]

Ý KIẾN CHUYÊN MÔN

Về sự phù hợp của đề xuất Cấp độ 4 và phương án bảo đảm an ninh mạng đối với Hệ thống X-OR SECURE CLOUD

1. Phạm vi hồ sơ đã xem xét: [liệt kê phiên bản tài liệu, sơ đồ, báo cáo rủi ro, checklist, bằng chứng].

2. Ý kiến về ranh giới và loại hệ thống thông tin: [đồng ý/đề nghị sửa, nêu rõ].

3. Ý kiến về căn cứ đề xuất Cấp độ 4 theo Điều 14 Nghị định 331/2026/NĐ-CP: [nêu tiêu chí và bằng chứng].

4. Ý kiến về tính đầy đủ của báo cáo đánh giá rủi ro chi tiết: [nêu tồn tại].

5. Ý kiến về sự phù hợp của phương án quản lý, kỹ thuật và vận hành theo Cấp độ 4: [nêu tồn tại/điều kiện].

6. Kết luận: [đủ điều kiện trình thẩm định / cần hoàn thiện trước khi trình].

Nơi nhận	ĐẠI DIỆN ĐƠN VỊ CHUYÊN TRÁCH ANM
- Chủ quản HTTT; - Đơn vị vận hành; - Lưu: ...	(Ký, ghi rõ họ tên, chức danh) [CẦN BỔ SUNG]

PHỤ LỤC B

Mẫu tờ trình phê duyệt hồ sơ đề xuất Cấp độ 4

Kính trình: Công ty Cổ phần XOR CLOUD

Căn cứ kết quả thẩm định số ... ngày ... của [CƠ QUAN THẨM ĐỊNH] và ý kiến chuyên môn số ... ngày ... của [ĐƠN VỊ CHUYÊN TRÁCH ANM], [ĐƠN VỊ VẬN HÀNH] kính trình Chủ quản HTTT phê duyệt hồ sơ đề xuất Cấp độ 4 đối với Hệ thống X-OR SECURE CLOUD.

Nội dung trình	Đề xuất
Tên/phạm vi hệ thống	Hệ thống X-OR SECURE CLOUD; phạm vi theo sơ đồ as-built phiên bản [x].
Cấp độ	Cấp độ 4.
Căn cứ	[Điểm/khoản Điều 14 Nghị định 331/2026/NĐ-CP; hồ sơ bằng chứng]
Phương án bảo vệ	Theo hồ sơ phiên bản [x], ma trận 129 kiểm soát và kế hoạch xử lý tồn tại.
Điều kiện sau phê duyệt	Đóng tồn tại P0/P1; đánh giá điều kiện trước vận hành; duy trì giám sát, kiểm tra, đánh giá lại khi thay đổi.

PHỤ LỤC C

Dự thảo quyết định phê duyệt Cấp độ 4

CÔNG TY CỔ PHẦN XOR CLOUD

QUYẾT ĐỊNH

Về việc phê duyệt Cấp độ 4 đối với Hệ thống X-OR SECURE CLOUD

Điều 1. Phê duyệt Hệ thống X-OR SECURE CLOUD là hệ thống thông tin Cấp độ 4, với ranh giới và thành phần theo hồ sơ phiên bản [x] kèm theo Quyết định này.

Điều 2. Phê duyệt phương án bảo đảm an ninh mạng theo Cấp độ 4 và yêu cầu đơn vị vận hành triển khai đầy đủ các biện pháp quản lý, kỹ thuật, vận hành; hoàn thiện các điều kiện/tồn tại theo ý kiến thẩm định.

Điều 3. Đơn vị vận hành chịu trách nhiệm duy trì hiệu lực kiểm soát, cập nhật hồ sơ khi có thay đổi, tổ chức đánh giá rủi ro, kiểm tra, giám sát, ứng cứu và báo cáo theo quy định.

Điều 4. Quyết định này có hiệu lực kể từ ngày ký. Các đơn vị [liệt kê] chịu trách nhiệm thi hành Quyết định này.

Nơi nhận	ĐẠI DIỆN CHỦ QUẢN HTTT
- Như Điều 4; - Cơ quan thẩm định; - Lưu: VT, ...	(Ký, ghi rõ họ tên, chức danh và đóng dấu) [CẦN BỔ SUNG]

PHỤ LỤC D. MA TRẬN 129 KIỂM SOÁT CẤP ĐỘ 4

Trạng thái tại thời điểm lập mẫu: 1 Đạt; 21 Đang thực hiện; 6 Không đạt; 4 Cần xác minh; 97 Chưa đánh giá. Trạng thái này được giữ nguyên từ checklist, không tự động nâng lên Đạt.

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
C4-GOV-01	Pháp lý và hồ sơ cấp độ	Xác định ranh giới hệ thống	Triển khai theo tiêu chí: Mô tả đầy đủ control plane, data plane, mạng, lưu trữ, portal, giám sát, sao lưu, DC/colo và mọi phụ thuộc dùng chung; không chia nhỏ hình thức để hạ cấp độ. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Đang thực hiện. Khoảng trống: Đã cập nhật thiết kế mục tiêu theo BOM V4 09 server + 01 SAN và sáu zone; còn thiếu phê duyệt ranh giới, dataflow chi tiết, phụ thuộc DC/SOC/backup và bằng chứng thực tế.	Sơ đồ phạm vi; danh mục thành phần/phụ thuộc; biên bản phê duyệt ranh giới	Chủ quản/CTO	P0	NĐ 331 Điều 6-15
C4-GOV-02	Pháp lý và hồ sơ cấp độ	Xác định chủ quản và đơn vị vận hành	Triển khai theo tiêu chí: Có quyết định hoặc văn bản ủy quyền nêu rõ phạm vi, trách nhiệm, quyền hạn, thời hạn; không để trùng vai trò thẩm định với vận hành nếu thiếu cơ chế độc lập. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Áp dụng cho cả hạ tầng do doanh	Quyết định giao chủ quản; RACI; văn bản ủy quyền	Ban điều hành	P0	NĐ 331 Điều 4-5, 18

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			nghiệp tự vận hành và phần thuê colo/dịch vụ.				
C4-GOV-03	Pháp lý và hồ sơ cấp độ	Phân loại dịch vụ và hệ thống khách hàng	Triển khai theo tiêu chí: Lập danh mục hệ thống được phục vụ, dữ liệu, chủ quản, mức tác động và cấp độ dự kiến; cập nhật khi thêm dịch vụ hoặc khách hàng trọng yếu. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Không mặc định mọi public cloud đều là cấp 4; cấp độ do tiêu chí NĐ 331 và đánh giá rủi ro quyết định.	Service catalog; hồ sơ phân loại dữ liệu; danh mục tenant trọng yếu	GRC/Cloud Ops	P0	NĐ 331 Điều 6-15
C4-GOV-04	Pháp lý và hồ sơ cấp độ	Hồ sơ đề xuất cấp độ	Triển khai theo tiêu chí: Hồ sơ gồm thuyết minh tổng quan, thiết kế, căn cứ đề xuất cấp độ và phương án bảo đảm an ninh mạng; dùng đúng biểu mẫu và kiểm soát phiên bản. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Chuẩn bị bằng chứng as-designed và kế hoạch cập nhật as-built.	Bộ hồ sơ ký số/ký duyệt; danh mục Mẫu 01-08; lịch sử phiên bản	GRC/PMO	P0	NĐ 331 Điều 19-22 và Phụ lục
C4-GOV-05	Pháp lý và hồ sơ cấp độ	Tích hợp yêu cầu vào hồ sơ đầu tư	Triển khai theo tiêu chí: Phương án kỹ thuật trong báo cáo kinh tế-kỹ thuật, thiết kế cơ sở, kế hoạch thuê hoặc đề cương dự	Ma trận yêu cầu - hạng mục đầu tư - bản vẽ - tiêu chí	PMO/Kiến trúc	P0	NĐ 331 Điều 19, 21, 37

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			toán phải thể hiện biện pháp theo cấp độ đề xuất. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Đang thực hiện. Khoảng trống: Phương án V2 đã liên kết vai trò máy chủ, card mạng, VLAN và vật tư; còn thiếu ma trận truy vết NĐ 331/TCVN 14423 và phê duyệt đầu tư.	nghiệm thu			
C4-GOV-06	Pháp lý và hồ sơ cấp độ	Thẩm định/phê duyệt cấp 4	Triển khai theo tiêu chí: Xin ý kiến chuyên môn; Bộ Công an chủ trì thẩm định (trừ thẩm quyền chuyên ngành); chủ quản phê duyệt. Dự trù tối đa 25 ngày làm việc thẩm định và 07 ngày phê duyệt. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Cần lập đánh giá rủi ro chi tiết làm căn cứ và xin ý kiến chuyên môn.	Văn bản gửi/tiếp nhận; ý kiến thẩm định; quyết định phê duyệt	GRC/Pháp chế	P0	NĐ 331 Điều 18, 20, 22-25
C4-GOV-07	Pháp lý và hồ sơ cấp độ	Trường hợp thuộc danh mục quan trọng	Triển khai theo tiêu chí: Nếu hệ thống cấp 3/4 đồng thời đủ tiêu chí hệ thống thông tin quan trọng về an ninh quốc gia, thực hiện trình tự như cấp 5 và áp dụng yêu cầu tương ứng. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành.	Biên bản rà soát tiêu chí; ý kiến cơ quan chuyên trách	GRC/Pháp chế	P0	NĐ 331 Điều 16-20

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			Hiện trạng: Chưa đánh giá. Khoảng trống: Không dùng checklist cấp 3/4 này để thay checklist cấp 5.				
C4-GOV-08	Pháp lý và hồ sơ cấp độ	Phân tách khi thuê DC/cloud	Triển khai theo tiêu chí: Hệ thống tách lô-gic với hệ thống khác; các vùng mạng tách lô-gic và kiểm soát truy cập; phân vùng lưu trữ tách lô-gic. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: NĐ 331 áp dụng cùng yêu cầu lô-gic cho cấp 3 và 4; phân tách vật lý là yêu cầu cấp 5/hệ thống quan trọng.	Sơ đồ L3/VRF/VLAN/VXLAN; ACL/firewall; tenant/storage isolation test	Kiến trúc/NetOps	P0	NĐ 331 Điều 30
C4-GOV-09	Pháp lý và hồ sơ cấp độ	Quản lý chuyển tiếp TT 12/NĐ 85	Triển khai theo tiêu chí: Chỉ dùng bộ hồ sơ cũ cho dự án đang đầu tư/xây dựng trước 01/07/2026 trong thời hạn chuyển tiếp; mọi hệ thống phải đạt điều kiện NĐ 331 trong 12 tháng từ 01/07/2026. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: TT 12/2022 là nguồn di sản, không phải căn cứ chính cho kiến trúc mới.	Biên bản xác định diện chuyển tiếp; kế hoạch đóng khoảng trống	GRC/Pháp chế	P0	NĐ 331 Điều 39
C4-GO	Pháp lý và hồ sơ	Duy trì hồ sơ as-built	Triển khai theo tiêu chí: Cập nhật hồ sơ cấp độ, sơ đồ, danh mục tài sản và phương án	As-built; biên bản change review;	PMO/GRC	P0	NĐ 331 Điều 19-21, 31-33

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
V-10	cấp độ		khi mở rộng/nâng cấp hoặc thay đổi làm ảnh hưởng biện pháp bảo vệ. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Không đạt. Khoảng trống: Bundle vẫn 07 node và LVM/no-Ceph. Thiết kế mục tiêu đã đổi từ 14 node sang 09 server: 03 Controller, 03 Compute, 03 Ceph SSD, 01 SAN. Cần inventory, port map, vai trò Network đồng vị trí, cấu hình và as-built được duyệt; chưa có nghiệm thu.	quyết định cập nhật cấp độ nếu cần			
C4-LEG-01	Điều kiện cung cấp dịch vụ	Thông báo/đăng ký dịch vụ DC và cloud	Triển khai theo tiêu chí: Hoàn tất thủ tục áp dụng theo Luật Viễn thông và NĐ 163 trước khi cung cấp; lưu biên nhận, thông tin công bố và cập nhật khi thay đổi. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Chốt chính xác hình thức thủ tục theo mô hình pháp nhân và dịch vụ tại thời điểm nộp.	Hồ sơ gửi cơ quan quản lý; biên nhận; thông tin doanh nghiệp/dịch vụ công khai	Pháp chế	P0	Luật VT Điều 29, 41; NĐ 163
C4-LEG-02	Điều kiện cung cấp dịch vụ	Công bố chất lượng và SLA	Triển khai theo tiêu chí: Công khai chất lượng dịch vụ; định nghĩa cách đo availability, maintenance, credit, RPO/RTO, hỗ trợ, thông báo sự cố và loại	SLA; SLO/SLI; dashboard; báo cáo tháng; chính sách credit	Product/Legal/SRE	P0	Luật VT Điều 29; dự thảo mục 4.2.8, Phụ

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			trừ. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: SLA phải đo được riêng control plane và data plane; không dùng số marketing không có log nguồn.				lục Đ
C4-LEG-03	Điều kiện cung cấp dịch vụ	Bảo mật dữ liệu khách hàng	Triển khai theo tiêu chí: Không truy cập, khai thác hoặc sử dụng dữ liệu khách hàng nếu không có căn cứ/đồng ý; thiết lập cơ chế truy cập hỗ trợ có phê duyệt, thời hạn và log. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Ưu tiên mô hình khách hàng kiểm soát khóa cho workload nhạy cảm.	Điều khoản dịch vụ; DPA; PAM/JIT logs; báo cáo truy cập hỗ trợ	Legal/Security	P0	Luật VT Điều 29; Luật PDP
C4-LEG-04	Điều kiện cung cấp dịch vụ	Mô hình trách nhiệm chung	Triển khai theo tiêu chí: Công bố rõ trách nhiệm nhà cung cấp/khách hàng cho IAM, guest OS, network, encryption, backup, logging, incident, data exit và xóa dữ liệu. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Dự thảo TCVN Cloud yêu cầu biểu mẫu nhưng chưa có hiệu lực; vẫn là thực hành cần thiết	Ma trận trách nhiệm; service description; hợp đồng mẫu	Product/GRC	P0	Hợp đồng; dự thảo Phụ lục G

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			cho public cloud.				
C4-LEG-05	Điều kiện cung cấp dịch vụ	Quy trình yêu cầu hợp pháp/takedown	Triển khai theo tiêu chí: Có đầu mối 24/7, xác minh thẩm quyền, bảo toàn chứng cứ, ngăn chặn/tạm ngừng đúng phạm vi, ghi log và báo cáo; kiểm soát mốc 24 giờ hoặc 06 giờ khi quy định áp dụng. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: NĐ 333 nêu trực tiếp doanh nghiệp hosting/DC và các doanh nghiệp dịch vụ liên quan; pháp chế xác nhận phạm vi cho từng sản phẩm cloud.	SOP; danh sách đầu mối; mẫu phiếu; nhật ký quyết định; diễn tập	Legal/SOC/NOC	P0	NĐ 333
C4-LEG-06	Bảo vệ dữ liệu cá nhân	Xác định vai trò xử lý dữ liệu	Triển khai theo tiêu chí: Lập bản đồ vai trò bên kiểm soát, bên xử lý hoặc đồng kiểm soát cho billing, IAM, support, telemetry và dữ liệu workload; ký DPA phù hợp. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Vai trò có thể khác nhau theo từng luồng dữ liệu, không gán một vai trò cho toàn bộ dịch vụ.	Data map; ROPA; DPA; điều khoản subprocessor	DPO/Legal	P0	Luật 91/2025; NĐ 356/2025
C4-LEG-07	Bảo vệ dữ liệu cá nhân	Đánh giá tác động và chuyển dữ liệu	Triển khai theo tiêu chí: Thực hiện hồ sơ đánh giá tác động xử lý và đánh giá chuyển dữ liệu ra nước ngoài khi phát sinh; quản lý	DPIA/DTIA; data residency matrix; hồ sơ nộp/điều chỉnh;	DPO/Legal	P0	Luật 91/2025; NĐ 356/2025

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			vị trí lưu trữ, subprocessor và sao lưu. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Bao gồm log hỗ trợ, telemetry và bản sao lưu ngoài lãnh thổ.	hợp đồng			
C4-LEG-08	Bảo vệ dữ liệu cá nhân	Quyền chủ thể, lưu giữ và xóa	Triển khai theo tiêu chí: Có kênh tiếp nhận, xác minh và xử lý yêu cầu; thời hạn lưu giữ theo mục đích; xóa/ẩn danh trên primary, replica, snapshot và backup theo chính sách. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Nêu rõ giới hạn xóa tức thời đối với backup bất biến và chu kỳ hết hạn.	DSR workflow; retention schedule; deletion certificate; test khôi phục/xóa	DPO/Product/Ops	P0	Luật 91/2025; NĐ 356/2025
C4-LEG-09	Bảo vệ dữ liệu cá nhân	Ứng phó vi phạm dữ liệu	Triển khai theo tiêu chí: Tích hợp phân loại sự cố dữ liệu cá nhân, đánh giá phạm vi, bảo toàn chứng cứ, thông báo và phối hợp khách hàng/cơ quan có thẩm quyền. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Cam kết hợp đồng phải cho phép khách hàng đáp ứng thời hạn pháp lý của họ.	Playbook; mẫu thông báo; contact tree; nhật ký diễn tập	DPO/SOC/Legal	P0	Luật 91/2025; NĐ 356/2025

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
C4-RM-01	Quản lý rủi ro	Quy định và quy trình quản lý rủi ro	Triển khai theo tiêu chí: Ban hành quy trình nhận diện, đánh giá, xử lý, theo dõi và truyền thông rủi ro; rà soát ít nhất 06 tháng/lần và khi thay đổi đáng kể. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Bao gồm rủi ro multi-tenant, insider, supply chain, DC, mất vùng và phụ thuộc control plane.	Chính sách; risk methodology; lịch rà soát; biên bản phê duyệt	CISO/GRC	P0	TCVN 14423:6.1
C4-RM-02	Quản lý rủi ro	Risk register và kế hoạch xử lý	Triển khai theo tiêu chí: Mỗi rủi ro có tài sản, mối đe dọa, lỗ hổng, tác động, khả năng, chủ sở hữu, biện pháp, rủi ro còn lại và hạn hoàn thành. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Không chấp nhận rủi ro P0/P1 bằng email không có thẩm quyền và ngày hết hạn.	Risk register; treatment plan; acceptance sign-off	CISO/GRC	P0	TCVN 14423:6.1.2
C4-RM-03	Quản lý rủi ro	Đánh giá thay đổi lớn	Triển khai theo tiêu chí: Thực hiện threat modeling/risk review trước khi thêm dịch vụ, nâng cấp OpenStack, đổi backend storage, mở region/AZ hoặc thay mạng biên. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành.	Threat model; architecture decision record; security sign-off	Architecture/ Security	P0	TCVN 14423:6.1

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			Hiện trạng: Chưa đánh giá. Khoảng trống: Gắn quyết định triển khai với change ticket và kế hoạch rollback.				
C4-AST-01	Tài sản phần cứng	CMDB phần cứng	Triển khai theo tiêu chí: Kiểm kê máy chủ, switch, firewall, storage, HSM, OOB, PDU và thiết bị DC; có owner, vị trí, serial, IP/MAC, vai trò, support/EOL và trạng thái. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Đang thực hiện. Khoảng trống: BOM V4 liệt kê 09 server, 01 SAN, 02 Nexus, 02 FortiGate 500E, 01 switch SAN và 01 Access. Sheet định giá còn 10 server; thiếu serial/IP/MAC, model SAN/switch, vòng đời/support và đối soát asset vật tư.	CMDB export; đối soát rack; biên bản kiểm kê năm	ITAM/DC Ops	P0	TCVN 14423:6.2.2.1
C4-AST-02	Tài sản phần cứng	Phát hiện tài sản chưa quản lý	Triển khai theo tiêu chí: Quét/phát hiện kết nối trái phép tối thiểu 01 lần/quý; cô lập, điều tra và cập nhật CMDB. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Dùng DHCP logging và đối soát IPAM/MAC/LLDP; quản lý cả BMC/iDRAC.	NAC/NDR logs; scan report; incident/change ticket	NetOps/SOC	P1	TCVN 14423:6.2.2.2-6.2.2.4

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
C4-AST-03	Tài sản phần cứng	Vòng đời và hỗ trợ	Triển khai theo tiêu chí: Không đưa thiết bị hết hỗ trợ vào dịch vụ trọng yếu nếu thiếu chấp thuận rủi ro, firmware còn vá, vật tư thay thế và kế hoạch thay thế có hạn. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Cần xác minh. Khoảng trống: Máy chủ Dell R630 và FortiGate 500E cần bằng chứng EOL/EOS, hỗ trợ phần cứng/firmware, license/subscription, phụ tùng và kế hoạch thay thế; không suy ra còn support từ việc có thiết bị trong BOM.	EOL/EOS matrix; support contract; spares list; refresh plan	ITAM/Procurement	P0	TCVN 14423:6.2; quản lý rủi ro
C4-AST-04	Tài sản phần cứng	Thanh lý/chuyển giao an toàn	Triển khai theo tiêu chí: Phê duyệt chuyển giao; xóa an toàn, hủy khóa, xóa cấu hình, cập nhật CMDB và lưu biên bản chuỗi bàn giao. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Đặc biệt với SSD, ổ Cinder, cache, BMC và thiết bị mạng.	Media sanitization record; chain of custody; CMDB change	ITAM/Security	P1	TCVN 14423:6.2.2.3-6.2.2.5
C4-SW-01	Tài sản phần mềm	SBOM và danh mục phần mềm	Triển khai theo tiêu chí: Kiểm kê OpenStack/Kolla, OS, container images, firmware, agent, portal và thư viện; có phiên bản, nguồn, license, owner, CPE và	SBOM; software CMDB; image manifest; license/support list	Platform/SecOps	P0	TCVN 14423:6.3.2.1

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			ngày hết hỗ trợ. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Bao gồm Ansible collections và các gói offline trong bundle.				
C4-SW-02	Tài sản phần mềm	Danh sách cho phép	Triển khai theo tiêu chí: Chỉ triển khai gói/image từ kho đã duyệt; khóa nguồn, digest và chữ ký; ngăn cài đặt trái phép. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Không đạt. Khoảng trống: Registry hiện khai insecure=true. Báo cáo Trivy lab còn Critical có bản vá trong registry:3 và các image khác; cần TLS/trust, khóa digest/chữ ký, xử lý blocker và quét lại.	Allowlist; registry policy; admission/deployment logs	Platform/SecOps	P0	TCVN 14423:6.3.2.2-6.3.2.4
C4-SW-03	Tài sản phần mềm	Phần mềm còn hỗ trợ	Triển khai theo tiêu chí: Bảo đảm toàn bộ phần mềm được phép sử dụng còn thời gian hỗ trợ; rà soát tối thiểu hàng năm và trước nâng cấp lớn. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Đối chiếu phiên bản OpenStack/Kolla/Ubuntu và firmware thiết bị.	Support matrix; vendor notice; upgrade roadmap	Platform/ITAM	P0	TCVN 14423:6.3.2.3

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
C4-SW-04	Tài sản phần mềm	Đối soát bản dựng	Triển khai theo tiêu chí: Tạo manifest bất biến của bundle, artifact và cấu hình; kiểm tra checksum trước cài; lưu provenance và kết quả build/release. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Đạt. Khoảng trống: Checksum bundle đã khớp tệp .sha256; vẫn cần ký số và kiểm soát nguồn phát hành.	SHA-256; signed manifest; release evidence; reproducible build report	DevSecOps	P1	Dự thảo 4.2.13 và Phụ lục E
C4-SW-05	Tài sản phần mềm	Quét lỗ hổng image	Triển khai theo tiêu chí: Quét image máy ảo/container trước publish và định kỳ; chặn mức nghiêm trọng theo policy; xử lý false positive có phê duyệt/hết hạn. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Đang thực hiện. Khoảng trống: Báo cáo lab 02/09/2026 đã quét 38/38 image và đối chiếu đủ digest, nhưng release gate FAIL: 6 Critical có bản vá và 6 runtime SSH host private key. Chưa bao phủ host, DAST, pentest hoặc production.	Scan report; registry gate; exception register; re-scan evidence	DevSecOps/ SecOps	P0	TCVN 14423:6.7; dự thảo 4.2.2.2.5
C4-DAT-01	Quản lý dữ liệu	Phân loại và chủ sở hữu dữ liệu	Triển khai theo tiêu chí: Phân loại dữ liệu tenant, dữ liệu vận hành, log, backup, khóa và bí mật; gán owner, vị trí, luồng, thời hạn lưu giữ và phương pháp xóa. Phương án phải được cấu hình, kiểm thử và gắn owner;	Data inventory; classification; owner register; retention schedule	DPO/Data Owner	P0	TCVN 14423:6.4.2.1-6.4.2.2

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Tách dữ liệu khách hàng khỏi dữ liệu vận hành và dữ liệu hỗ trợ.				
C4-DAT-02	Quản lý dữ liệu	Rà soát quyền dữ liệu	Triển khai theo tiêu chí: Rà soát phân quyền dữ liệu tối thiểu 01 lần/quý; thu hồi quyền thừa và ghi nhận phê duyệt của owner. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Bao gồm quyền đọc snapshot/volume/image và DB control plane.	ACL export; review sign-off; revocation tickets	Data Owner/IAM	P0	TCVN 14423:6.4.2.1-6.4.2.3
C4-DAT-03	Quản lý dữ liệu	Mã hóa dữ liệu quan trọng	Triển khai theo tiêu chí: Mã hóa dữ liệu quan trọng khi lưu trữ và truyền; quản lý khóa tách biệt dữ liệu; luân chuyển, thu hồi và khôi phục khóa có kiểm soát. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Mức 4 theo dự thảo yêu cầu HSM cho master key và không tắt mã hóa mặc định; hiện dùng làm thiết kế mục tiêu.	Encryption config; KMS logs; key lifecycle; crypto inventory	Security/Platform	P0	TCVN 14423:6.4.2.4; dự thảo 5.4
C4-	Quản lý	Toàn vẹn và luồng	Triển khai theo tiêu chí: Tài liệu hóa	DFD; API	Architecture/Data	P1	TCVN

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
DAT-04	dữ liệu	dữ liệu	nguồn-đích, giao thức, trust boundary, dữ liệu nhạy cảm; xác minh toàn vẹn khi truyền/đồng bộ và dùng chữ ký số cho dữ liệu quan trọng khi phù hợp. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Bao gồm replication, migration, backup và export khách hàng.	inventory; hash/signature logs; data lineage			14423:6.4.2.5-6.4.2.10
C4-DAT-05	Quản lý dữ liệu	Tách biệt xử lý/lưu trữ	Triển khai theo tiêu chí: Tách theo mức độ nhạy cảm; không dùng chung vùng quản trị/khóa/log cho dữ liệu có yêu cầu khác nếu làm suy giảm kiểm soát. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Đang thực hiện. Khoảng trống: BOM V4 mục tiêu chỉ có 03 Ceph SSD và 01 SAN, không có cụm Ceph HDD. Đề xuất VLAN 30 client và 31 cluster; SAN có backend/fabric riêng cần chốt. Bundle vẫn LVM/no-Ceph; cần CRUSH/replication, ACL, phân tách dữ liệu theo mức nhạy cảm và kiểm thử isolation.	Storage pool/host aggregate map; ACL; isolation test	Architecture/ Storage	P0	TCVN 14423:6.4.2.7
C4-DAT	Quản lý dữ liệu	DLP và log truy cập dữ liệu quan	Triển khai theo tiêu chí: Triển khai DLP phù hợp và lưu log truy cập dữ liệu quan	DLP policy; data access logs; alert/use	SOC/DPO	P1	TCVN 14423:6.4.2.

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
-06		trọng	trọng; cảnh báo xuất lượng lớn hoặc hành vi bất thường. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Không ghi bí mật/PII không cần thiết vào log.	case; export approval			8-6.4.2.9
C4-CFG-01	Cấu hình an toàn	Baseline cấu hình	Triển khai theo tiêu chí: Ban hành baseline cho OS, hypervisor, network, firewall, DB, message bus, container, OpenStack service và BMC; quản lý ngoại lệ có owner/hết hạn. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Tham chiếu CIS Benchmark/vendor hardening nhưng map lại TCVN.	Baseline; compliance scan; exception register	Platform/SecOps	P0	TCVN 14423:6.5.2.1
C4-CFG-02	Cấu hình an toàn	Khóa phiên và timeout	Triển khai theo tiêu chí: Tự khóa phiên quản trị sau thời gian không hoạt động; giới hạn phiên/token; không duy trì phiên đặc quyền dùng chung. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Kiểm thử Horizon, CLI/API, SSH, VPN, firewall và iDRAC.	IAM/PAM policy; config export; test case	IAM/Platform	P1	TCVN 14423:6.5.2.2

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
C4-CFG-03	Cấu hình an toàn	Tắt dịch vụ không cần thiết	Triển khai theo tiêu chí: Gỡ/tắt package, port, service, sample account, browser/email client và protocol không cần trên control/compute/network/storage nodes. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Dùng deny-by-default và kiểm soát thay đổi để ngăn drift.	Port/service inventory; hardening scan; golden image	Platform/SecOps	P1	TCVN 14423:6.5.2.3
C4-CFG-04	Cấu hình an toàn	DNS/NTP/PKI tin cậy	Triển khai theo tiêu chí: Dùng DNS tin cậy; tối thiểu hai nguồn thời gian; PKI nội bộ/được duyệt; giám sát lệch giờ và vòng đời chứng thư. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Không để TLS/log/audit phụ thuộc vào DNS/NTP đơn điểm lỗi.	DNS/NTP/PKI design; cert inventory; drift/expiry alerts	Platform/NetOps	P1	TCVN 14423:6.5; dự thảo 4.2.1, 4.2.8
C4-IAM-01	IAM và đặc quyền	Kho tài khoản tập trung	Triển khai theo tiêu chí: Quản lý tập trung người dùng, service account, API credential và tài khoản đặc quyền; mỗi tài khoản cá nhân có owner và trạng thái. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Tích hợp Keystone	IAM export; owner mapping; account inventory	IAM	P0	TCVN 14423:6.6.2.1

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			federation/IdP; tránh local account trừ break-glass.				
C4-IAM-02	IAM và đặc quyền	MFA tài khoản quản trị	Triển khai theo tiêu chí: Bật MFA cho mọi quản trị từ portal/API/VPN/PAM; không cho bypass trừ break-glass kiểm soát. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Theo dự thảo, mục tiêu mức 4 dùng yếu tố phần cứng chống sao chép cho tài khoản đặc quyền.	MFA policy; enrollment report; negative test	IAM/Security	P0	TCVN 14423:6.6.2.2; dự thảo 5.5.2.3
C4-IAM-03	IAM và đặc quyền	RBAC và least privilege	Triển khai theo tiêu chí: Tách vai trò cloud admin, security, network, storage, IAM, billing, auditor và support; cấp quyền tối thiểu theo project/domain. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Không dùng tài khoản admin chung; kiểm thử API enforcement, không chỉ UI.	Role matrix; Keystone policy; quarterly review	IAM/Platform	P0	TCVN 14423:6.6.2.3-6.6.2.5
C4-IAM-04	IAM và đặc quyền	Vòng đời tài khoản	Triển khai theo tiêu chí: Phê duyệt cấp mới/thay đổi/thu hồi; vô hiệu hóa tài khoản không hoạt động sau 45 ngày hoặc ngay khi nhân sự thay đổi; rà soát ít nhất mỗi quý.	JML tickets; HR feed; review sign-off; stale account report	IAM/HR	P0	TCVN 14423:6.6

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Bao gồm API key, robot/service account, credential trên CI/CD và tài khoản nhà thầu.				
C4-IAM-05	IAM và đặc quyền	PAM/JIT và ghi phiên	Triển khai theo tiêu chí: Đặc quyền qua PAM/bastion, cấp theo thời gian/sự vụ, phê duyệt, ghi lệnh/phiên, cảnh báo hành vi và thu hồi tự động. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Tách quyền trên host khỏi quyền đọc dữ liệu tenant; áp dụng dual control cho thao tác nguy hiểm.	PAM logs; session recording; JIT approval; break-glass report	Security/IAM	P0	TCVN 14423:6.6; dự thảo 4.2.6
C4-IAM-06	IAM và đặc quyền	Quản lý bí mật	Triển khai theo tiêu chí: Không lưu mật khẩu/secret ở plain text trong site-config, repository, image hoặc ticket; dùng vault, rotation, short-lived credential và secret scanning. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Không đạt. Khoảng trống: Trivy phát hiện 6 SSH host private key thực được đóng trong image nova-ssh/keystone-ssh; đồng thời cần xác minh trường	Vault inventory; scan report; rotation logs; redacted config	Security/ DevSecOps	P0	TCVN 14423:6.6; dự thảo 4.2.13.2.7

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			ssh_password. Phải loại khóa khỏi image, sinh/rotate riêng khi deploy và quét lại.				
C4-VUL-01	Lỗ hổng và bản vá	Quy trình quản lý lỗ hổng	Triển khai theo tiêu chí: Bao phủ internet, nội bộ, authenticated scan, container/image, hypervisor, network, firmware và ứng dụng; có SLA theo mức nghiêm trọng. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Đang thực hiện. Khoảng trống: Báo cáo Trivy lab bao phủ 38 runtime image cùng source/offline artifact. Còn thiếu chính sách/SLA, host/hypervisor/network authenticated scan, guest image, API/DAST và kết quả production sau khắc phục.	Vulnerability policy; scan coverage; remediation SLA dashboard	SecOps/Owners	P0	TCVN 14423:6.7.2.1
C4-VUL-02	Lỗ hổng và bản vá	Quy trình bản vá	Triển khai theo tiêu chí: Đánh giá, thử nghiệm, triển khai cuốn chiếu, xác minh và rollback; xử lý emergency patch; ngoại lệ có biện pháp bù và hết hạn. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Thiết kế để vá control plane/network/storage không làm mất quorum hoặc gián đoạn ngoài SLA.	Patch policy; test record; change/rollback; compliance report	Platform/NetOps	P0	TCVN 14423:6.7.2.2

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
C4-VUL-03	Lỗ hổng và bản vá	Theo dõi cảnh báo và CVE	Triển khai theo tiêu chí: Theo dõi vendor/CISA/NVD/BCA; map CVE vào SBOM; ưu tiên theo exposure, exploitability và dữ liệu, không chỉ CVSS. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Đang thực hiện. Khoảng trống: Trivy đã ánh xạ CVE, package, fixed version và thứ tự xử lý; cần bổ sung threat feed định kỳ, ticket/SLA, đánh giá exposure và quy trình VEX/ngoại lệ có phê duyệt.	Threat feed; SBOM-CVE mapping; triage tickets	SOC/SecOps	P1	TCVN 14423:6.7
C4-LOG-01	Nhật ký và giám sát	Chính sách nhật ký	Triển khai theo tiêu chí: Xác định nguồn, trường, mức log, retention, quyền truy cập, đồng bộ giờ, bảo vệ PII/secret và trách nhiệm rà soát. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Bao gồm Keystone, Nova, Neutron, Cinder, Glance, DB, RabbitMQ, HAProxy, OS, firewall, switch, iDRAC và DC.	Logging standard; source matrix; retention; access review	SOC/Platform	P0	TCVN 14423:6.8.2.1
C4-LOG-02	Nhật ký và giám sát	Thu thập tập trung và SIEM	Triển khai theo tiêu chí: Chuyển log near-real-time về hệ thống tập trung độc lập; phát hiện mất nguồn log; phân quyền và mã hóa đường truyền. Phương án phải được cấu hình, kiểm thử và gắn owner; không	SIEM source health; TLS config; ingestion/latency dashboard	SOC/Platform	P0	TCVN 14423:6.8; 6.13

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Log bảo vệ không phụ thuộc hoàn toàn vào chính cloud được giám sát.				
C4-LOG-03	Nhật ký và giám sát	Bảo vệ toàn vẹn log	Triển khai theo tiêu chí: Chống sửa/xóa, tách quyền quản trị, hash/immutable storage và đồng bộ thời gian; bảo đảm truy vết cá nhân cho hành vi đặc quyền. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Mức 4 nên có chuỗi hành trình chứng cứ hoặc thủ tục bù theo dự thảo.	WORM/ immutability config; hash validation; admin separation test	SOC/Security	P0	TCVN 14423:6.8; dự thảo 4.2.9, 5.9
C4-LOG-04	Nhật ký và giám sát	Use case và cảnh báo	Triển khai theo tiêu chí: Có rule cho brute force, privilege escalation, policy bypass, cross-tenant scan, metadata abuse, key export, bulk data export, log stop, time drift và config drift. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Đo false positive/false negative và rà soát ngưỡng sau thay đổi.	Use-case catalog; alert test; incident tickets; tuning record	SOC	P0	TCVN 14423:6.13.2
C4-LOG	Nhật ký và giám	NOC/SOC liên tục	Triển khai theo tiêu chí: Theo dõi tập trung 24/7 với escalation, on-call, health	Roster; on-call test; MTTD/MTTR;	SOC/NOC/SRE	P0	TCVN 14423:6.13

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
-05	sát		dashboard và khả năng cô lập khẩn cấp đã kiểm thử. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Tách giám sát an ninh với giám sát khả dụng nhưng liên kết sự kiện.	escalation log			
C4-MAL-01	Mã độc và endpoint	Phòng chống mã độc/EDR	Triển khai theo tiêu chí: Triển khai, cập nhật và quản lý tập trung EDR/anti-malware phù hợp trên máy quản trị, bastion, server hỗ trợ; cảnh báo về SIEM. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Với appliance/container không cài agent, dùng compensating control và file/image scanning.	Coverage report; policy; update health; test alert	SecOps	P1	TCVN 14423:6.9-6.10
C4-MAL-02	Mã độc và endpoint	Web/email/DNS filtering	Triển khai theo tiêu chí: Chỉ cho phép trình duyệt/email ở vùng người dùng; lọc DNS/URL, sandbox tệp, chặn domain độc hại; không cài trên node hạ tầng. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Áp dụng cho máy quản trị và kênh nhận artifact; node cloud dùng	Proxy/DNS policy; endpoint baseline; blocked event	SecOps/IT	P2	TCVN 14423:6.9.2

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			egress allowlist.				
C4-BKP-01	Sao lưu và khôi phục	Chính sách backup theo RPO/RTO	Triển khai theo tiêu chí: Phân loại dữ liệu và xác định tần suất, retention, RPO/RTO, owner, encryption, offsite, quy trình restore và tiêu chí thành công. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Tách trách nhiệm backup nền tảng và backup workload của khách hàng.	Backup policy; service-tier RPO/RTO; job matrix	SRE/Storage	P0	TCVN 14423:6.11.2.1
C4-BKP-02	Sao lưu và khôi phục	Backup tự động và giám sát	Triển khai theo tiêu chí: Tự động sao lưu DB/config/secret/registry/image/volume theo phạm vi; cảnh báo job fail, dung lượng, retention và replication lag. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Bao gồm MariaDB/Galera, RabbitMQ definitions, Keystone, Neutron, Glance, Cinder metadata và portal.	Job config; success/failure logs; alert tickets	SRE/Storage	P0	TCVN 14423:6.11.2.2
C4-BKP-03	Sao lưu và khôi phục	Bảo vệ và tách biệt backup	Triển khai theo tiêu chí: Mã hóa, quyền riêng, tài khoản/credential riêng; kho backup tách hạ tầng chính và có bản ngoài failure domain. Phương án phải được cấu	Backup ACL; encryption; network/storage diagram;	Security/Storage	P0	TCVN 14423:6.11.2.3-6.11.2.4

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Một bản sao trong cùng rack/LVM host không được coi là bản tách biệt.	ransomware test			
C4-BKP-04	Sao lưu và khôi phục	Kiểm tra khôi phục	Triển khai theo tiêu chí: Kiểm tra khôi phục theo lịch và đo RTO/RPO; diễn tập full restore nhóm tài nguyên đại diện; xử lý mọi sai lệch. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Mức 4: TCVN yêu cầu kiểm tra khả năng khôi phục; dự thảo yêu cầu diễn tập full restore theo chu kỳ.	Restore test report; checksum; achieved RTO/RPO; corrective actions	SRE/BCM	P0	TCVN 14423:6.11.2.5; dự thảo 5.10.4
C4-BKP-05	Sao lưu và khôi phục	Backup bất biến	Triển khai theo tiêu chí: Bật chế độ bất biến cho backup control plane và dữ liệu khách hàng thuộc dịch vụ backup; tách quyền xóa và có break-glass. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Dự thảo TCVN Cloud chưa có hiệu lực nhưng là mục tiêu chống ransomware quan trọng.	Immutability policy; retention lock; delete test; break-glass log	Storage/Security	P0	Dự thảo 5.10.2.2
C4-	Hạ tầng	Sơ đồ mạng và	Triển khai theo tiêu chí: Duy trì sơ đồ vật	L2/L3 diagrams;	NetOps/	P0	TCVN

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
NET-01	mạng	trust zone	lý/lô-gic, luồng north-south/east-west, VIP, routing, firewall, LB, management, storage, migration, tenant và external; cập nhật khi thay đổi. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Đang thực hiện. Khoảng trống: Đã vẽ zone và hạ tầng A/B theo 09 server + 01 SAN. Phác thảo dùng VLAN 10/20/30/31/40/70/99/100, khác ý nghĩa VLAN trong bảng tính cũ; còn thiếu bản phê duyệt L2/L3/IP/VRF/VXLAN, chuyển đổi VLAN và port matrix.	dataflow; port matrix; change-linked version	Architecture		14423:6.12.2.1
C4-NET-02	Hạ tầng mạng	Phân vùng và deny-by-default	Triển khai theo tiêu chí: Tách OOB, management, API, storage, migration, tunnel, provider, tenant, DMZ, backup, monitoring; mọi liên vùng qua policy được duyệt và log. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Đang thực hiện. Khoảng trống: Quy hoạch đề xuất tách internal 10, tenant 20, Ceph client/cluster 30/31, security 40, API private 70, OOB 99 và portal 100; external/provider và SAN cần chốt. BOM V4 không có Ceph HDD; còn	VRF/VLAN/ VXLAN map; firewall/ACL export; isolation tests	NetOps/Security	P0	TCVN 14423:6.12.2.2-6.12.2.4; NĐ 331 Điều 30

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			thiếu ACL/firewall/VRF/VXLAN và negative isolation test.				
C4-NET-03	Hạ tầng mạng	Truy cập quản trị từ xa	Triển khai theo tiêu chí: Qua VPN/ZTNA và bastion/PAM; MFA, thiết bị quản trị được quản lý, giới hạn nguồn/giờ, ghi phiên và chặn split tunnel khi cần. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Không mở SSH/API quản trị trực tiếp ra Internet.	Remote access policy; VPN/ZTNA config; session logs; test	Security/NetOps	P0	TCVN 14423:6.12.2.5
C4-NET-04	Hạ tầng mạng	Giao thức quản trị an toàn	Triển khai theo tiêu chí: Dùng SSHv2, HTTPS/TLS, SNMPv3, AAA tập trung; tắt Telnet/HTTP/SNMPv1v2c; quản lý cipher/cert. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Bao gồm Nexus, Fortigate, iDRAC, switch OOB, PDU và BMS gateway.	Config compliance; port scan; TLS report	NetOps/SecOps	P1	TCVN 14423:6.12.2.3
C4-NET-05	Hạ tầng mạng	Tài nguyên quản trị riêng	Triển khai theo tiêu chí: Dành riêng bastion, PAM, admin workstation, AAA, DNS/NTP/PKI và kênh OOB; không chạy phụ thuộc vòng trên tenant cloud. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay	Admin zone diagram; dependency test; cold-start runbook	Architecture/ NetOps	P0	TCVN 14423:6.12.2.6

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: seed_ha hiện để trống; cần kênh khôi phục độc lập và kiểm thử cold start.				
C4-NET-06	Hạ tầng mạng	DDoS/WAF/API protection	Triển khai theo tiêu chí: Anti-DDoS nhiều lớp, WAF/API gateway, rate limit, bot/credential abuse defense, health check và runbook chuyển hướng/scrubbing. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Một đường Internet 1 Gbps không chứng minh năng lực DDoS hoặc dự phòng nhà mạng.	Capacity/contract; WAF rules; rate-limit test; DDoS exercise	NetOps/SOC	P0	TCVN 14423:6.13; NĐ 333
C4-NET-07	Hạ tầng mạng	Dự phòng mạng biên	Triển khai theo tiêu chí: Hai tuyến/nhà mạng độc lập, router/firewall/switch HA, uplink kép, ECMP/BGP hoặc cơ chế tương đương; kiểm thử mất từng thành phần. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Không đạt. Khoảng trống: BOM có 02 FortiGate 500E và 02 Nexus. OPEX thêm tuyến backup IP Transit/BGP nhưng chưa có hợp đồng/giá; phác thảo vẫn một ISP. Chưa chứng minh hai last-mile độc lập,	Carrier contracts; route diagram; failover report; packet loss/MTTR	NetOps/SRE	P0	Khả dụng/rủi ro; TCVN 9250

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			routing/failover; switch SAN và Access mỗi loại chỉ 01.				
C4-NET-08	Hạ tầng mạng	Ánh xạ NIC và băng thông	Triển khai theo tiêu chí: Mỗi vai trò NIC có cổng vật lý/port-channel hợp lệ, MTU thống nhất, dự phòng uplink và headroom; kiểm thử bonding/LACP/failover. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Đang thực hiện. Khoảng trống: BOM có 18 NDC 25 Gb, 18 PCI 25 Gb, 09 card LAN dual port, 36 DAC và 26 RJ45, chưa có phân bổ từng máy. Controller 10 Gb và phác thảo 25 Gb chưa thống nhất; mode active–passive/active–active và MTU phải chốt, đo iperf/failover.	NIC-to-switch map; switch config; iperf/failover results	NetOps/Platform	P0	TCVN 14423:6.12; quản lý cấu hình
C4-MON-01	Giám sát và phòng thủ	Firewall/IDS/ IPS/NDR	Triển khai theo tiêu chí: Bật và quản lý tập trung firewall, IDS/IPS/NDR tại biên và vùng trọng yếu; rule có owner, ticket, hết hạn; kiểm thử chữ ký/hành vi. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Tách firewall tenant self-service và firewall bảo vệ hạ tầng.	Policy/rule review; coverage map; detection test	SOC/NetOps	P0	TCVN 14423:6.13.2.1-6.13.2.4

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
C4-MON-02	Giám sát và phòng thủ	Telemetry mạng	Triển khai theo tiêu chí: Thu thập flow, DNS, LB/WAF, firewall, switch và host telemetry; giữ định danh tenant/project và đồng bộ giờ để điều tra cross-tenant. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Không thu nội dung khách hàng vượt mục đích/pháp lý.	NetFlow/IPFIX; packet metadata; tenant mapping test	SOC/NetOps	P1	TCVN 14423:6.13.2.4
C4-MON-03	Giám sát và phòng thủ	Giám sát khả dụng và capacity	Triển khai theo tiêu chí: Theo dõi CPU/RAM/disk/IOPS/latency/queue/quorum/cert/time sync/temperature/power; forecast capacity và cảnh báo trước saturation. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Giám sát tải PDU/rack, cổng 10/25 Gb, Ceph rebuild và Internet 1 Gbps. Rack_Power V4 tính tải ước tính 4,3894 kW và cực đại thiết kế 6,491 kW; 9 kW là công suất hợp đồng đề xuất, không phải số đo tải thực. Cần telemetry và cảnh báo theo tải/độ dự phòng được phê duyệt.	Monitoring dashboard; thresholds; capacity report; alert tests	NOC/SRE/DC Ops	P0	TCVN 14423:6.13; dự thảo 4.2.8
C4-	Nhân sự	Bộ phận chuyên	Triển khai theo tiêu chí: Có bộ phận/đầu	Sơ đồ tổ chức; JD;	Ban điều	P0	TCVN

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
PEO-01	và nhà cung cấp	trách	mối vận hành, quản trị và an ninh mạng; trực 24/7 theo SLA; phân tách nhiệm vụ và kiểm soát chéo. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Không giao một người toàn quyền IAM, khóa, hạ tầng và audit.	RACI; roster/on-call	hành/CISO		14423:6.14; NĐ 331 Điều 31-33
C4-PEO-02	Nhân sự và nhà cung cấp	Đào tạo theo vai trò	Triển khai theo tiêu chí: Đào tạo nhận thức và đào tạo chuyên sâu theo vai trò tối thiểu hàng năm; kiểm tra năng lực cho admin, SOC, SRE, developer và DC operator. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Bao gồm thao tác phá hủy, cô lập tenant, bảo toàn chứng cứ và PCCC.	Training plan; attendance; test result; competency matrix	HR/CISO	P1	TCVN 14423:6.14.2
C4-PEO-03	Nhân sự và nhà cung cấp	Kiểm kê và phân loại nhà cung cấp	Triển khai theo tiêu chí: Lập danh mục colo, ISP, phần cứng, phần mềm, MSSP, backup, KMS và subprocessor; phân loại criticality/data access/failure dependency. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Theo dõi hỗ trợ và nguồn linh kiện cho Dell R630,	Vendor register; due diligence; dependency map	Procurement/GRC	P1	TCVN 14423:6.15

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			Nexus và Fortigate.				
C4-PEO-04	Nhân sự và nhà cung cấp	Điều khoản bảo mật nhà cung cấp	Triển khai theo tiêu chí: Hợp đồng quy định SLA, bảo mật, DPA, audit, thông báo sự cố, vá lỗi, BCP/DR, subprocessor, data exit/xóa và hỗ trợ điều tra. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Đảm bảo quyền lấy bằng chứng DC/colo và kết quả diễn tập.	Security schedule; DPA; SLA; right-to-audit; exit plan	Legal/Procurement	P0	TCVN 14423:6.15.2
C4-PEO-05	Nhân sự và nhà cung cấp	Giám sát và kết thúc hợp đồng	Triển khai theo tiêu chí: Theo dõi SLA/rủi ro/certification; thu hồi truy cập, lấy/xóa dữ liệu, chuyển giao cấu hình và bằng chứng khi chấm dứt. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Không phụ thuộc độc quyền mà thiếu export/restore test.	Vendor review; offboarding checklist; deletion certificate	GRC/Procurement	P1	TCVN 14423:6.15
C4-IR-01	Ứng phó và liên tục	Lực lượng và đầu mối ứng phó	Triển khai theo tiêu chí: Thành lập CSIRT, đầu mối nội bộ/khách hàng/ISP/DC/cơ quan chuyên trách; xác minh danh bạ hàng năm và có kênh ngoài băng. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh	Decision; contact tree; out-of-band channel test	CISO/SOC	P0	TCVN 14423:6.16/6.17; NĐ 333

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			giá. Khoảng trống: Áp dụng cả sự cố an ninh, data breach, mất DC, lỗi diện rộng và abuse.				
C4-IR-02	Ứng phó và liên tục	Playbook sự cố	Triển khai theo tiêu chí: Có playbook phát hiện, phân loại, cô lập, bảo toàn hiện trường/chứng cứ, khắc phục, phục hồi, truyền thông và báo cáo. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Playbook riêng cho credential leak, hypervisor escape, cross-tenant, ransomware, DDoS và mất quorum.	IR plan; playbooks; case record; evidence handling	SOC/SRE/Legal	P0	TCVN 14423:6.16/6.17; NĐ 333 Điều 9
C4-IR-03	Ứng phó và liên tục	Diễn tập và hậu kiểm	Triển khai theo tiêu chí: Diễn tập tối thiểu hàng năm, gồm kỹ thuật và lãnh đạo; đánh giá sau sự cố/diễn tập, theo dõi hành động tới khi đóng. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Kịch bản nên có failover DC/ISP/storage/control plane và yêu cầu pháp lý.	Exercise report; timeline; lessons learned; action tracker	CISO/BCM	P0	TCVN 14423:6.17.2.5-6.17.2.7
C4-IR-04	Ứng phó và liên tục	BIA/BCP/DR	Triển khai theo tiêu chí: BIA xác định dịch vụ trọng yếu, MTPD, RTO/RPO, phụ thuộc và thứ tự phục hồi; BCP/DR có site,	BIA; BCP/DR plan; dependency map; exercise evidence	BCM/SRE	P0	TCVN 14423:6.11; quản lý rủi ro

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			runbook, quyền, dữ liệu và tiêu chí tuyên bố thảm họa. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Một rack tại một DC không xử lý được sự cố mất site.				
C4-DEV-01	DevSecOps và kiểm thử	SDLC an toàn	Triển khai theo tiêu chí: Threat modeling, coding standard, peer review, SAST/SCA/secret/IaC scan, test, ký artifact, approval và rollback trước production. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Đang thực hiện. Khoảng trống: Trivy chứng minh đã quét vulnerability/misconfiguration/secret, đối chiếu digest và có SBOM/provenance cho lab; gate vẫn FAIL và chưa có đầy đủ threat model, SAST, approval, rollback và pipeline production.	SDLC; pipeline evidence; security gates; release approval	Engineering/ DevSecOps	P0	TCVN 14423:6.16.2.1
C4-DEV-02	DevSecOps và kiểm thử	Tiếp nhận lỗ hổng và RCA	Triển khai theo tiêu chí: Có kênh disclosure, triage/SLA, phối hợp CVE; phân tích nguyên nhân gốc và phòng tái diễn cho lỗ hổng nghiêm trọng. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng	VDP; ticket; RCA; regression test	Product Security	P1	TCVN 14423:6.16.2.2-6.16.2.4

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Cho phép khách hàng/bên nghiên cứu báo cáo an toàn.				
C4-DEV-03	DevSec Ops và kiểm thử	Tách dev/test/prod	Triển khai theo tiêu chí: Tách tài khoản, mạng, dữ liệu, secrets, CI runner và quyền triển khai; cấm dùng dữ liệu thật ở test nếu chưa bảo vệ phù hợp. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Production change qua pipeline/approval, không sửa tay không lưu dấu vết.	Environment diagram; IAM; network test; data masking	Engineering/ Security	P0	TCVN 14423:6.16.2.5
C4-DEV-04	DevSec Ops và kiểm thử	Chương trình pentest	Triển khai theo tiêu chí: Phạm vi/phương pháp/thời gian/đầu mối và bảo vệ dữ liệu được phê duyệt; kiểm thử Internet-facing tối thiểu hàng năm; khắc phục và re-test. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Trivy là quét lỗ hổng/cấu hình/secret, không phải pentest; không kiểm thử DAST, API authorization, tenant escape, runtime traffic hoặc management plane. Vẫn cần pentest độc lập và re-test.	Rules of engagement; pentest report; remediation/re-test	Security	P0	TCVN 14423:6.18.2.1-6.18.2.4

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
C4-DEV-05	DevSecOps và kiểm thử	Pentest nội bộ	Triển khai theo tiêu chí: Thực hiện pentest nội bộ tối thiểu hàng năm đối với tài nguyên nội bộ và vùng quản trị; theo dõi khắc phục/re-test. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Báo cáo Trivy không thay thế pentest nội bộ/lateral movement. Cần phạm vi nội bộ, rules of engagement, báo cáo khai thác, remediation và re-test riêng.	Internal pentest; lateral movement report; re-test	Security	P0	TCVN 14423:6.18.2.5
C4-CLD-01	OpenStack và multi-tenant	Đối soát topology as-built	Triển khai theo tiêu chí: Chốt số node/vai trò/AZ/failure domain; tự động kiểm tra inventory với CMDB và hồ sơ thiết kế trước triển khai. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Đang thực hiện. Khoảng trống: BOM V4 mục tiêu 09 server: 03 Controller (1–2 SEED), 03 Compute, 03 Ceph SSD; thêm 01 SAN. Không còn node Network riêng/Ceph HDD. Bundle 07 node chưa được thay bằng inventory và nghiệm thu thống nhất.	Kolla inventory; CMDB diff; as-built; acceptance sign-off	Platform/PMO	P0	Quản lý tài sản/cấu hình
C4-CLD	OpenStack và	Ảo hóa phần cứng	Triển khai theo tiêu chí: Dùng KVM/hardware virtualization, kiểm tra VT-	Nova config; CPU flags; performance	Platform	P1	Dự thảo 4.2.2, 4.2.8

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
-02	multi-tenant		x/AMD-V/IOMMU, CPU model compatibility và live migration; qemu software emulation chỉ cho lab/ngoại lệ. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Đang thực hiện. Khoảng trống: Topology và phương án xác định compute chạy KVM; site-config hiện vẫn ghi qemu. Cần Nova config, CPU flags VT-x/AMD-V/IOMMU, benchmark và migration compatibility test.	benchmark; migration matrix			
C4-CLD-03	OpenStack và multi-tenant	HA control plane	Triển khai theo tiêu chí: Ba controller duy trì quorum; Galera/RabbitMQ/HAProxy/Keepalived và API services chạy HA, giám sát split-brain/quorum và kiểm thử mất từng node. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Đang thực hiện. Khoảng trống: Topology có 3 controller và mô tả MariaDB/RabbitMQ, HAProxy/Keepalived; chưa có quorum dashboard, node-loss, split-brain hoặc cold-start test.	HA design; quorum dashboard; node-loss test; recovery runbook	Platform/SRE	P0	TCVN 14423:6.12-6.13; dự thảo 4.2.8
C4-	OpenSta	HA network node	Triển khai theo tiêu chí: Hai network node	Neutron agents; HA	Platform/NetOps	P0	TCVN

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
CLD-04	ck và multi-tenant		active/active hoặc active/standby có state sync phù hợp; kiểm thử L3/DHCP/metadata/NAT/LB failover và session impact. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Đang thực hiện. Khoảng trống: BOM V4 không có 02 network node riêng; Server 4–6 là Compute, một số cột cũ còn ghi Network. Network agent/gateway đồng vị trí là đề xuất, chưa chốt placement/HA/Neutron/OVN, uplink và kiểm thử L3/DHCP/metadata/NAT.	router state; failover test			14423:6.12-6.13
C4-CLD-05	OpenStack và multi-tenant	Backend lưu trữ HA	Triển khai theo tiêu chí: Dùng storage phân tán/shared có replication, quorum và failure domain độc lập; hoặc công bố rõ local-volume không HA kèm replication/backup và giới hạn dịch vụ. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Đang thực hiện. Khoảng trống: Mục tiêu 03 Ceph SSD với 10 ổ 1,92 TB phân bố 4/3/3, VLAN client/cluster 30/31 đề xuất; 01 SAN 24 × 600 GB SAS cần chốt backend, RAID, giao thức và MPIO. Bundle vẫn LVM/no-Ceph; thiếu	Storage design; replica/failure-domain map; disk/node-loss test; SLA	Storage/ Architecture	P0	TCVN 14423:6.11-6.13; dự thảo 4.2.8

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			production config, usable capacity và disk/node/path-loss test.				
C4-CLD-06	OpenStack và multi-tenant	Live migration và maintenance	Triển khai theo tiêu chí: Xác định phạm vi CPU/storage hỗ trợ live migration, host maintenance, evacuation và rollback; kiểm thử không gián đoạn theo service tier. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Đang thực hiện. Khoảng trống: Thiết kế KVM + Ceph tạo tiền đề cho shared storage/live migration; vẫn cần CPU compatibility matrix, migration/evacuation/maintenance test và downtime thực đo.	Migration matrix; maintenance test; achieved downtime	Platform/SRE	P1	Dự thảo 4.2.8.2.5-4.2.8.2.14
C4-CLD-07	OpenStack và multi-tenant	Keystone federation và policy	Triển khai theo tiêu chí: Tích hợp IdP, MFA, domain/project isolation, application credential, token lifetime/revocation; kiểm thử RBAC ở từng API. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Tách admin domain, service users và tenant users.	Keystone config; policy tests; token/MFA evidence	IAM/Platform	P0	TCVN 14423:6.6; dự thảo 4.2.4
C4-CLD	OpenStack và	Barbican/KMS/HSM	Triển khai theo tiêu chí: Quản lý khóa volume/image/secret bằng KMS tách biệt;	KMS architecture; key lifecycle;	Security/Platform	P0	TCVN 14423:6.4;

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
-08	multi-tenant		rotation/revocation/backup; HSM cho khóa chủ theo mục tiêu cấp 4. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Không để khóa và dữ liệu cùng failure/administrative domain.	restore/revoke test			dự thảo 4.2.5, 5.4
C4-CLD-09	OpenStack và multi-tenant	Bảo vệ metadata service	Triển khai theo tiêu chí: Ngăn truy cập metadata giữa tenant/VM; dùng cơ chế xác thực; không để platform credential/chi tiết hạ tầng; cho tenant vô hiệu hóa khi cần. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Kiểm thử đường 169.254.169.254 và proxy/agent metadata của Neutron.	Metadata config; cross-tenant negative test; SSRF test	Platform/Security	P0	Dự thảo 4.2.2.2.10
C4-CLD-10	OpenStack và multi-tenant	Neutron anti-spoof và security group	Triển khai theo tiêu chí: Default deny, port security, anti-spoof MAC/IP, RA/DHCP guard, tenant/project isolation và log enforcement tại nguồn. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Kiểm thử east-west, shared network, provider network, trunk và allowed-address-pair.	Neutron policy; cross-tenant test; flow/security logs	Platform/NetOps	P0	TCVN 14423:6.12-6.13; dự thảo 4.2.3

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
C4-CLD-11	OpenStack và multi-tenant	Glance image trust	Triển khai theo tiêu chí: Chỉ publish image có nguồn, checksum/chữ ký, scan sạch theo policy, baseline và lịch cập nhật; tenant image có quarantine/scan phù hợp. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Kiểm soát cả image Fedora CoreOS/k8s-airgap trong cấu hình.	Image catalog; signed metadata; scan result; update log	Platform/ DevSecOps	P0	TCVN 14423:6.3, 6.7; dự thảo 4.2.2.2.5
C4-CLD-12	OpenStack và multi-tenant	Cinder mã hóa và xóa an toàn	Triển khai theo tiêu chí: Mã hóa volume theo tier, secure erase/crypto erase khi thu hồi, kiểm soát snapshot/clone/export và ghi bằng chứng xóa. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Local LVM cần chứng minh zeroization giữa tenant và xử lý SSD/TRIM/snapshot.	Cinder type/config; KMS; deletion test/log; tenant isolation test	Storage/Security	P0	TCVN 14423:6.4, 6.11; dự thảo 4.2.7
C4-CLD-13	OpenStack và multi-tenant	Nova placement và failure domain	Triển khai theo tiêu chí: Dùng host aggregate/AZ, anti-affinity, quota và resource reservation; không đặt replica của cùng dịch vụ vào cùng host/PDU/switch path. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết	Placement config; failure-domain map; scheduling tests	Platform/SRE	P1	Dự thảo 4.2.8

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Đang thực hiện. Khoảng trống: BOM V4 có 03 Compute và 03 Ceph SSD, thêm 01 SAN; không còn 06 Ceph node. Cần AZ/host aggregate, anti-affinity, placement cho network đồng vị trí, ánh xạ PDU/switch/fabric/failure domain, quota/reservation và kiểm thử N+1 khi mất host/path.				
C4-CLD-14	OpenStack và multi-tenant	Quota, rate limit và chống noisy neighbor	Triển khai theo tiêu chí: Quota theo tenant; giới hạn CPU/RAM/IOPS/bandwidth/API; cảnh báo saturation; fairness queue và capacity reserve. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Công bố overcommit và giới hạn gói; tránh overcommit RAM cho dịch vụ yêu cầu cao.	Quota policy; rate-limit test; noisy-neighbor benchmark	Product/Platform	P1	Dự thảo 4.2.8.2.11-4.2.8.2.13
C4-CLD-15	OpenStack và multi-tenant	Metering và billing có truy vết	Triển khai theo tiêu chí: Đo usage theo tenant, đồng bộ giờ, chống trùng/mất bản ghi, đối soát với resource state; phân tách quyền sửa giá/usage/hóa đơn. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh	Metering reconciliation; audit logs; billing controls	FinOps/Product	P1	Luật VT; kiểm soát toàn vẹn/log

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			giá. Khoảng trống: Billing dispute phải truy ngược được tới event/resource ID.				
C4-CLD-16	OpenStack và multi-tenant	Tên miền/IP production	Triển khai theo tiêu chí: Thay toàn bộ example/test CIDR, domain, NS và credential; xác minh quyền sở hữu IP/ASN/domain, DNSSEC khi phù hợp và TLS public. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Không đạt. Khoảng trống: site-config còn 203.0.113.0/24, cloud.example.com và ns1.example.com.	Production IP/domain plan; DNS/TLS validation; config scan	NetOps/Platform	P0	Quản lý cấu hình/an toàn mạng
C4-CLD-17	OpenStack và multi-tenant	Seed/khôi phục độc lập	Triển khai theo tiêu chí: Có seed/bastion/repository/credential escrow đủ để dựng lại control plane khi toàn bộ nền tảng dừng; không phụ thuộc vòng và kiểm thử định kỳ. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Đang thực hiện. Khoảng trống: Topology có seed01/seed02 và phương án đặt SEED trên Controller 1-2; tính độc lập khi control plane mất toàn bộ chưa rõ, site-config seed_ha còn trống. Cần cold-start/restore drill.	Cold-start runbook; offline artifacts; restore drill	SRE/Platform	P0	Dự thảo 4.2.8.2.1
C4-	Trung	Chọn chuẩn và	Triển khai theo tiêu chí: Chọn một trong	Quyết định chuẩn;	DC	P0	TT 42 Điều

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
DC-01	tâm dữ liệu	mức bảo đảm DC	TCVN 9250:2021, ANSI/TIA-942-B:2017, ANSI/TIA-942-C:2024 hoặc Tier của Uptime Institute; xác định mức/rating theo BIA và SLA. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Đang thực hiện. Khoảng trống: Site Nam Thăng Long vẫn là giả định chưa chốt hợp đồng/rack. Bản công bố 20/10/2023 nêu Tier III TCDD thiết kế, không nêu TCCF. OPEX V4 dẫn báo giá Vdigicom; tên bên báo giá chưa chứng minh site và nhà vận hành thực tế. Cần hợp đồng, địa chỉ/phạm vi site và hồ sơ DC hiện hành.	gap assessment; design/certification scope	Owner/Architecture		3-5
C4-DC-02	Trung tâm dữ liệu	Công bố phù hợp DC	Triển khai theo tiêu chí: Trước khai thác thương mại, hoàn tất tự đánh giá/chứng nhận theo chuẩn đã chọn, công bố phù hợp, gửi/đăng thông tin theo quy định và duy trì hồ sơ. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Cần xác minh. Khoảng trống: Đã có bản công bố năm 2023 cho Nam Thăng Long; cần chứng minh còn phù hợp TT 42/2025, đã gửi/đăng và đúng	Bản công bố; báo cáo đánh giá/chứng nhận; bằng chứng gửi và đăng website	DC Owner/Legal	P0	TT 42 Điều 5 và Phụ lục

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			phòng/rack. ISO 9001 có NTL đã hết hạn; các ISO 9001/50001 khác, ISO 27001 và PCI DSS không đúng site/phạm vi hoặc đã hết hạn.				
C4-DC-03	Trung tâm dữ liệu	Chống sét và tiếp đất	Triển khai theo tiêu chí: Tuân thủ QCVN 32:2020/BTTTT và QCVN 9:2016/BTTTT; đo, nghiệm thu, kiểm định/bảo trì và quản lý thay đổi. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Đối soát SPD, chống sét lan truyền và nối đất rack/thiết bị.	Thiết kế; biên bản đo/kiểm tra; sơ đồ bonding/grounding; lịch bảo trì	DC Ops/M&E	P0	TT 42 Điều 4
C4-DC-04	Trung tâm dữ liệu	Vị trí và rủi ro môi trường	Triển khai theo tiêu chí: Không đặt phòng máy ở tầng cao, tầng hầm hoặc dưới nơi chứa nước; tránh khu dễ cháy, kho dầu và nguồn điện/từ trường mạnh; đánh giá lũ, động đất, giao thông và lân cận. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Kiểm tra cả tuyến điện/cáp và vị trí máy phát/bồn nhiên liệu.	Site risk assessment; bản vẽ mặt bằng/cao độ; BIA	DC Owner/M&E	P0	TCVN 14423 Phụ lục A.4.1
C4-DC-05	Trung tâm dữ liệu	Kiểm soát ra vào	Triển khai theo tiêu chí: Cổng điện tử, nhật ký, camera tập trung giám sát 24/7 lưu tối thiểu 06 tháng; vành đai; camera và tủ bảo	Access logs; CCTV retention/config; visitor/media log;	Physical Security	P0	TCVN 14423 Phụ lục A.4.2

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			vệ cho máy chủ/thiết bị mạng quan trọng. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Phân quyền theo khu/rack; quy trình cấp quyền tạm thời và thu hồi.	access review			
C4-DC-06	Trung tâm dữ liệu	Chống trộm/phá hoại và cáp	Triển khai theo tiêu chí: Rack cố định, khóa, gắn nhãn; cáp đi ngầm/ống bảo vệ; báo động chống trộm tự động và giám sát mở cửa/tamper. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Cấp 4 yêu cầu báo động dùng quang điện hoặc kỹ thuật tương đương.	Rack/cabling inspection; alarm test; photo/asset labels	DC Ops/Physical Security	P1	TCVN 14423 Phụ lục A.4.3
C4-DC-07	Trung tâm dữ liệu	PCCC tự động	Triển khai theo tiêu chí: Cảnh báo/chữa cháy tự động, tín hiệu âm thanh và ánh sáng; vật liệu chịu lửa; khu máy chủ/thiết bị mạng quan trọng cách ly và có biện pháp cách lửa. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Thiết kế clean agent/VESDA/EPO/cửa chống cháy theo hồ sơ được cơ quan có thẩm quyền duyệt.	Thiết kế thẩm duyệt; nghiệm thu; cause-effect test; maintenance; drill	DC Owner/PCCC	P0	TCVN 14423 Phụ lục A.4.5; pháp luật PCCC

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
C4-DC-08	Trung tâm dữ liệu	Chống thấm/rò nước	Triển khai theo tiêu chí: Không có ống nước qua trần/sàn phòng máy; ngăn nước mưa, phát hiện rò rỉ và có phương án thoát/di chuyển nước tích tụ. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Đặt cảm biến dưới sàn, gần CRAC và tuyến ống; tích hợp BMS/NOC.	MEP drawings; leak sensor map/test; inspection record	DC Ops/M&E	P0	TCVN 14423 Phụ lục A.4.6
C4-DC-09	Trung tâm dữ liệu	Chống tĩnh điện	Triển khai theo tiêu chí: Chống tĩnh điện cho mọi thiết bị trong phòng máy và sàn chống tĩnh điện; đo/kiểm tra định kỳ. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Kiểm soát ESD khi bảo trì/thay linh kiện.	Floor specification; grounding/bonding test; inspection	DC Ops/M&E	P1	TCVN 14423 Phụ lục A.4.7
C4-DC-10	Trung tâm dữ liệu	Nhiệt độ, độ ẩm và làm mát	Triển khai theo tiêu chí: Điều hòa phòng máy riêng hoàn toàn hệ thống tòa nhà; đo/cảnh báo độ ẩm; có hút ẩm; theo dõi 24/7 và dự phòng phù hợp tải. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Rack_Power V4 tính tải	CFD/thermal survey; sensor calibration; trend/alarm; failover test	DC Ops/M&E	P0	TCVN 14423 Phụ lục A.4.8; TCVN 9250

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			ước tính 4,3894 kW và cực đại thiết kế 6,491 kW; 9 kW là công suất hợp đồng đề xuất. Chưa có đo tải PDU hoặc hồ sơ cooling tại site. Cần containment, airflow phù hợp từng model, dự phòng N+1 và kiểm thử ở tải được phê duyệt.				
C4-DC-11	Trung tâm dữ liệu	Nguồn điện và UPS	Triển khai theo tiêu chí: Nguồn ổn định/chống quá tải; hai nguồn kéo từ hai trạm điện khác nhau; UPS cho toàn bộ thiết bị hệ thống/máy chủ và kiểm thử chuyển nguồn. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Cần xác minh. Khoảng trống: Rack_Power V4 đề xuất 6 kW cơ sở + 01 block 3 kW = 9 kW; OPEX còn công thức #REF!, chưa chứng minh công suất đã ký. Chưa có A/B feed hoặc số đo UPS/generator autonomy; cần hợp đồng điện, single-line, PDU mapping và load/failover test.	Single-line diagram; utility evidence; UPS runtime/load test; ATS test	DC Ops/M&E	P0	TCVN 14423 Phụ lục A.4.9
C4-DC-12	Trung tâm dữ liệu	Phân phối điện A/B	Triển khai theo tiêu chí: Dual PSU của server/network nối PDU A/B khác nhau; breaker/circuit có headroom và chọn lọc bảo vệ; đo tải từng nhánh, không chung	Rack elevation; PDU mapping; breaker study; failover test	DC Ops/M&E	P0	TCVN 9250/chuẩn DC đã chọn

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			điểm lỗi. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Kiểm tra cả Fortigate, Nexus, storage, console và OOB.				
C4-DC-13	Trung tâm dữ liệu	Máy phát và nhiên liệu	Triển khai theo tiêu chí: Có máy phát, ATS, nhiên liệu/tiếp nhiên liệu và định mức runtime theo BIA; chạy thử có tải, giám sát chất lượng nhiên liệu và hợp đồng tiếp tế. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Kịch bản mất điện kéo dài phải bao gồm cooling, security, network và staff.	Generator load test; fuel plan; ATS logs; vendor contract	DC Ops/M&E	P0	TCVN 9250/chuẩn DC đã chọn
C4-DC-14	Trung tâm dữ liệu	Bảo vệ điện từ	Triển khai theo tiêu chí: Tách cáp điện/tín hiệu; cách ly nguồn nhiễu; có tấm chắn điện từ cho khu vực máy chủ và thiết bị mạng quan trọng. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Bao gồm bonding/earthing và khoảng cách tuyến cáp.	Cabling layout; EMI assessment/measurement; inspection	DC Ops/M&E	P1	TCVN 14423 Phụ lục A.4.10
C4-	Trung	Cáp và meet-me-	Triển khai theo tiêu chí: Cáp cấu trúc, nhãn	Cable schedule;	DC Ops/NetOps	P1	TT 42;

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
DC-15	tâm dữ liệu	room	hai đầu, quản lý patch, tuyến A/B tách biệt, MMR/carrier entry tách failure domain và spare capacity. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Áp dụng TCVN 9250 hoặc chuẩn DC đã chọn trong phạm vi tuyên bố.	pathway drawing; OTDR/test results; MMR audit			TCVN 9250
C4-DC-16	Trung tâm dữ liệu	BMS/DCIM và cảnh báo	Triển khai theo tiêu chí: Giám sát điện, UPS, PDU, nhiệt/ẩm, nước, cooling, cửa, camera, cháy, máy phát; đồng bộ NOC/SOC, lưu lịch sử và kiểm thử cảnh báo. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Tách mạng OT/BMS khỏi tenant và management cloud; remote access qua PAM.	BMS/DCIM dashboards; alarm matrix; test tickets; retention	DC Ops/NOC	P1	TCVN 9250; TCVN 14423 Phụ lục A
C4-DC-17	Trung tâm dữ liệu	Bảo trì đồng thời và spare	Triển khai theo tiêu chí: Quy trình bảo trì không làm mất service tier; MOP/SOP/EOP, permit-to-work, change, spare critical, rollback và giám sát nhà thầu. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Cần xác minh. Khoảng trống: Uptime Tier III	MOP/SOP/EOP; maintenance test; spare inventory; RCA	DC Ops/SRE	P1	Chuẩn DC đã chọn/ISO 22301

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			TCDD là bằng chứng thiết kế, chưa chứng minh cơ sở đã xây dựng/vận hành đúng thiết kế hoặc bảo trì đồng thời. Cần TCCF/current certification, MOP/SOP/EOP và kết quả test.				
C4-DC-18	Trung tâm dữ liệu	DR site và khoảng cách rủi ro	Triển khai theo tiêu chí: Thiết kế site DR/region độc lập về điện, carrier, rủi ro địa lý và quyền quản trị; replication phù hợp RPO; diễn tập chuyển đổi và failback. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Không đạt. Khoảng trống: Kế hoạch hiện chỉ thể hiện một rack tại một DC; chưa có site DR độc lập.	Site risk comparison; replication design; DR drill; achieved RPO/RTO	BCM/Architecture	P0	Quản lý rủi ro/ISO 22301; dự thảo 5.7
C4-OPS-01	Vận hành dịch vụ cloud	Service catalog và tier	Triển khai theo tiêu chí: Mỗi dịch vụ/gói nêu rõ HA, AZ, storage, backup, encryption, support, quota, SLA, RPO/RTO và trách nhiệm khách hàng; không bán HA khi backend không hỗ trợ. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Tách rõ local-LVM volume không HA nếu chưa thay backend.	Service catalog; architecture-to-SLA mapping; approval	Product/ Architecture	P0	Luật VT; hợp đồng; quản lý rủi ro
C4-	Vận	Onboarding tenant	Triển khai theo tiêu chí: Xác minh khách	Onboarding	Cloud Ops/Product	P1	NĐ

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
OPS-02	hành dịch vụ cloud		hàng, tạo domain/project, quota, network baseline, MFA/admin, contact, data classification và acceptance của trách nhiệm chung. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Không dùng security group mở toàn bộ làm mặc định.	checklist; approved tenant baseline; contact/consent			331/TCVN 14423/hợp đồng
C4-OPS-03	Vận hành dịch vụ cloud	Offboarding và data exit	Triển khai theo tiêu chí: Cho phép export ở định dạng sử dụng được; xác minh owner; thu hồi quyền/route/IP/key; xóa an toàn và cấp bằng chứng sau retention. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Bao gồm snapshot, image, object, log hỗ trợ, billing record và backup.	Exit checklist; export/restore test; deletion certificate	Cloud Ops/DPO	P0	Luật VT/PDP; dự thảo 4.2.7, 5.11
C4-OPS-04	Vận hành dịch vụ cloud	Change/release management	Triển khai theo tiêu chí: Phân loại thay đổi, đánh giá tác động tenant/cấp độ, phê duyệt, canary/rolling, thông báo bảo trì, rollback và post-change validation. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Thay đổi	Change tickets; CAB; deployment/rollback logs; status notice	SRE/Platform	P0	TCVN 14423:6.5; dự thảo 4.2.8

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
			network/storage/identity/key phải có kiểm soát chéo.				
C4-OPS-05	Vận hành dịch vụ cloud	Capacity và headroom N+1	Triển khai theo tiêu chí: Tính công suất CPU/RAM/storage/IOPS/network/power/cooling ở failure state; dự báo tăng trưởng, đặt ngưỡng mua sắm và kiểm thử overload có kiểm soát. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Đang thực hiện. Khoảng trống: BOM V4 có 09 server với 2.304 GB RAM theo vai trò, Ceph 19,2 TB raw và SAN 14,4 TB raw. Chưa có headroom N+1, usable/IOPS/rebuild, network placement và power measured. Không dùng định giá 10 server hoặc băng thông bond tổng làm năng lực đã nghiệm thu.	Capacity model; N+1 calculations; forecast; procurement trigger	SRE/FinOps/DC Ops	P0	Khả dụng/rủi ro; dự thảo 4.2.8
C4-OPS-06	Vận hành dịch vụ cloud	Status page và truyền thông sự cố	Triển khai theo tiêu chí: Status page tách độc lập; template/mốc thông báo; đồng bộ giữa NOC/SOC/support/legal; post-incident report và SLA credit. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Không để kênh thông báo phụ thuộc vào cloud đang sự cố.	Status page; communication matrix; incident sample; PIR	Support/SRE/Legal	P1	Luật VT/NĐ 333; SLA

ID	Nhóm	Hạng mục	Phương án/hiện trạng	Bằng chứng tối thiểu	Chủ trì	Ưu tiên	Căn cứ
C4-OPS-07	Vận hành dịch vụ cloud	Đánh giá độc lập trước go-live	Triển khai theo tiêu chí: Thực hiện kiểm tra cấu hình, vulnerability, pentest, failover, restore, DC, privacy, pháp lý và hồ sơ cấp độ; P0 phải đóng hoặc được chấp thuận đúng thẩm quyền. Phương án phải được cấu hình, kiểm thử và gắn owner; không dùng thiết kế/tuyên bố thay bằng chứng vận hành. Hiện trạng: Chưa đánh giá. Khoảng trống: Nghiệm thu bằng bằng chứng thực thi, không chỉ tài liệu thiết kế.	Go-live gate; test pack; residual-risk acceptance; approval	CISO/CTO/GRC	P0	NĐ 331; TCVN 14423

PHỤ LỤC E. DANH MỤC BẰNG CHỨNG CẦN NỘP

Mã	Nhóm	Tài liệu/bằng chứng	Ưu tiên	Tình trạng
E-01	Pháp lý/chủ quản	Quyết định giao chủ quản, giao vận hành, đơn vị chuyên trách ANM; chức năng nhiệm vụ; RACI	P0	[CẦN BỔ SUNG]
E-02	Căn cứ Cấp độ 4	Tài liệu chứng minh tiêu chí Điều 14; BIA; phạm vi toàn quốc/24x7 hoặc risk conclusion	P0	[CẦN BỔ SUNG]
E-03	Thiết kế/as-built	Sơ đồ logical/physical/data-flow; IP/VLAN/VRF; ACL; rack/port map; CMDB/serial	P0	[CẦN BỔ SUNG]
E-04	DC/colo	TT42/TCCF; MEP A/B; UPS/gen; cooling; PCCC; grounding; BMS/DCIM; access/CCTV; MOP/SOP/EOP	P0	[CẦN XÁC MINH]
E-05	Mạng/Internet	Hợp đồng 2 ISP; BGP/ASN/IP; diverse path; Anti-DDoS; WAF/NGFW/IPS; failover test	P0	[CẦN BỔ SUNG]
E-06	OpenStack/KVM	globals/inventory; endpoint/TLS; RBAC; hardening; KVM proof; HA test; config baseline	P0	[CẦN BỔ SUNG]
E-07	Ceph	CRUSH/failure domain; pools/replica; CephX; encryption; health/capacity; failure/recovery test	P0	[CẦN BỔ SUNG]
E-08	Vulnerability/ supply chain	SBOM; signed image; Trivy/host/web/API scans; remediation; exceptions; scan lại PASS	P0	[KHÔNG ĐẠT - CHƯA ĐÓNG]
E-09	IAM/PAM	MFA/PAM/JIT; account inventory; access review; session record; break-glass test; key rotation	P0	[CẦN BỔ SUNG]
E-10	SOC/logging	Log source matrix; retention; immutable storage; use cases; on-call; alert/playbook test	P0	[CẦN BỔ SUNG]
E-11	Backup/DR	Policy 3-2-1-1-0; backup logs; restore evidence; DR site; DR drill; RTO/RPO report	P0	[KHÔNG ĐẠT - CHƯA CÓ DR SITE]
E-12	Pentest	SOW; report; tenant isolation; retest; closure evidence; risk acceptance	P0	[CẦN BỔ SUNG]

Mã	Nhóm	Tài liệu/bằng chứng	Ưu tiên	Tình trạng
E-13	Pháp lý cloud/data	Điều kiện cung cấp dịch vụ; SLA/DPA/shared responsibility; privacy impact; subcontractor	P0	[CẦN BỔ SUNG]
E-14	IR/BCP	IRP/playbooks; contact tree; tabletop/technical drill; post-incident; BCP/BIA	P1	[CẦN BỔ SUNG]
E-15	Vận hành	ITSM change/problem/capacity; patch reports; KPI/KRI; maintenance; audit/review records	P1	[CẦN BỔ SUNG]

PHỤ LỤC F. DANH MỤC CĂN CỨ VÀ TÀI LIỆU THAM CHIẾU

Mã	Căn cứ/tài liệu
PL-01	Luật An ninh mạng số 116/2025/QH15 ngày 10/12/2025.
PL-02	Nghị định số 331/2026/NĐ-CP ngày 19/08/2026 về bảo vệ an ninh mạng đối với hệ thống thông tin.
PL-03	Nghị định số 333/2026/NĐ-CP ngày 19/08/2026 quy định chi tiết một số điều và biện pháp thi hành Luật An ninh mạng.
TC-01	TCVN 14423:2026 - An ninh mạng - Hệ thống thông tin - Yêu cầu cơ bản (tài liệu bản quyền nội bộ, không phát hành lại).
DC-01	Thông tư số 42/2025/TT-BKHCN ngày 30/11/2025 quy định áp dụng tiêu chuẩn, quy chuẩn kỹ thuật đối với trung tâm dữ liệu.
DC-02	TCVN 9250:2021 - Trung tâm dữ liệu - Yêu cầu về hạ tầng kỹ thuật viễn thông.
VT-01	Luật Viễn thông số 24/2023/QH15 ngày 24/11/2023, hiệu lực 01/07/2024.
DP-01	Luật Bảo vệ dữ liệu cá nhân số 91/2025/QH15 ngày 26/06/2025, hiệu lực 01/01/2026.
FP-01	Quy định pháp luật hiện hành về phòng cháy, chữa cháy và cứu nạn, cứu hộ; hồ sơ thẩm duyệt/nghiệm thu của site.
INT-01	Baocaophuonganv2.xlsx và topology phương án trước; nguồn lịch sử, không dùng để chốt số lượng thiết bị giai đoạn 1 trong phiên bản 0.9.4.
INT-02	Public_Cloud_V2_Checklist_Cap_do_3_4.xlsx, sheet Cấp độ 4, 129 kiểm soát.
INT-03	Báo cáo Trivy lab ngày 02/09/2026 và thông tin cập nhật quét ngày 08/09/2026; chỉ dùng đúng phạm vi kiểm thử đã nêu.
INT-04	Bảng tính CAPEX/OPEX Cloud V4.xlsx: sheet Quy Hoạch Hạ Tầng Phần Cứng, Rack_Power, Rack_Layout_Visual và CAPEX/OPEX; nguồn quy mô

Mã	Căn cứ/tài liệu
	09 server + 01 SAN. Các xung đột nội bộ được ghi rõ trong thuyết minh.
INT-05	IMG_2827.jpg và IMG_2828.jpg: phác thảo kết nối, Portal–API Broker và quy hoạch VLAN đề xuất; không phải bản vẽ as-built hoặc biên bản nghiệm thu.
INT-06	image.png: tham khảo bố cục zone, màu và cách thể hiện. Không dùng số lượng/model thiết bị trong hình này thay cho BOM V4 hoặc bằng chứng thực tế.

Nguồn tra cứu chính thức: Cổng Thông tin điện tử Chính phủ (chinhphu.vn/vanban.chinhphu.vn), Cơ sở dữ liệu quốc gia về văn bản pháp luật và Cổng Công báo. Khi phát hành chính thức, pháp chế phải kiểm tra lại hiệu lực, văn bản sửa đổi/thay thế và phạm vi áp dụng tại ngày ký.

PHỤ LỤC G. CHECKLIST TRƯỚC KHI KÝ/TRÌNH

STT	Điều kiện	Xác nhận
1	Tên chủ quản, đơn vị vận hành, đơn vị chuyên trách ANM và cơ quan thẩm định đã đúng thẩm quyền.	☐
2	Tiêu chí Cấp độ 4 theo Điều 14 đã được chọn và có bằng chứng thuyết phục.	☐
3	Sơ đồ, BOM, IP/VLAN, model firewall, LVM/Ceph và số node đã thống nhất với as-built.	☐
4	Không còn placeholder, IP/domain mẫu, secret/key trong image hoặc tài liệu phát hành.	☐
5	Trivy/scan gate PASS và có pentest/retest độc lập.	☐
6	HA/failover/backup/restore/DR đã kiểm thử; RTO/RPO được đo và phê duyệt.	☐
7	Hồ sơ DC đúng site, còn hiệu lực và bao phủ TCCF/MEP/PCCC/grounding/access.	☐
8	Ma trận 129 kiểm soát có owner, trạng thái, bằng chứng, ngày hiệu lực và đường dẫn lưu.	☐
9	Ý kiến chuyên môn đã được tiếp thu/giải trình; hồ sơ có kiểm soát phiên bản.	☐
10	Toàn bộ trường Word, mục lục, số trang, chữ ký và dấu/ký số đã cập nhật.	☐